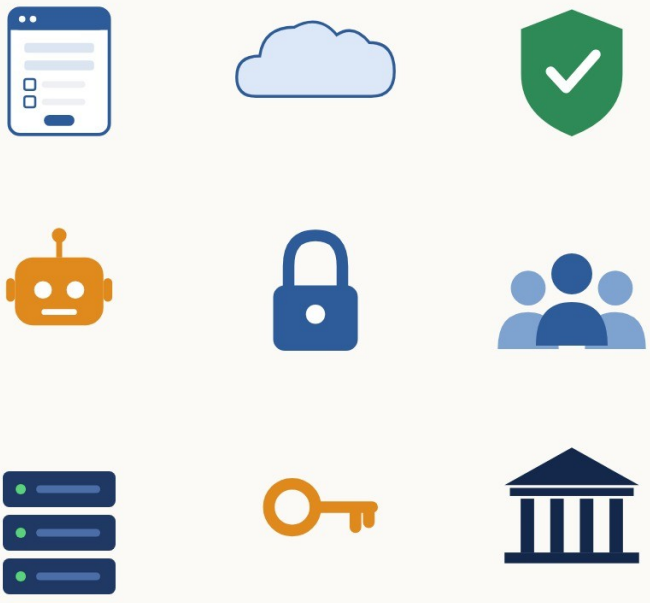
기술정책보고서

AI 시대,
설문·신청·수집 단계의
보안 위협과 대응

미인증 외부 설문도구의 해킹 침투경로 분석과 클라우드 보안인증 기반 대응 방안



2026. 11. 10.

한국컨설팅산업재단 | 개인정보보호진흥원

발간번호 2026-11-01

발 간 사

최근 공공기관과 기업을 가리지 않고 대규모 개인정보 유출 사고가 잇따르고 있습니다. 대통령 전용기 탑승자 명단이 외부 사이트에 노출되고, 공직자 10 만여 명의 정보가 외주업체의 옛 서버에서 유출되었으며, 수많은 기업이 함께 쓰는 업무 플랫폼까지 침해되었습니다. 국민의 개인정보 보호는 이제 한 기관의 관리 문제를 넘어 국가 신뢰의 문제가 되었습니다.

(재)한국컨설팅산업재단 부설 개인정보보호진흥원은 정보주체인 국민의 권리를 보장하고, 현장에서 실행할 수 있는 정책 대안을 찾기 위해 노력해 왔습니다. 공공기관의 온라인 개인정보 수집 실태를 진단하여 개선을 권고하고, 보안인증을 받은 온라인 조사 도구를 공공기관이 부담 없이 도입할 수 있도록 지원하는 사업을 추진하는 한편, 개인정보 보호 현장의 목소리를 정책 논의로 잇는 일에 힘쓰고 있습니다.

이 보고서는 그 가운데에서도 국민이 가장 쉽게 피해를 입을 수 있는 설문·신청·접수 단계, 즉 국민의 정보가 기관으로 처음 들어오는 길목에 주목하였습니다. 이 단계는 거의 모든 기관이 매일 운영하지만 보안의 사각지대로 남아 있는 경우가 많습니다. 여기에 AI 를 이용한 해킹이 빠르게 고도화되면서, 그동안 드러나지 않았던 작은 틈이 대규모 피해의 출발점이 될 수 있게 되었습니다.

이에 본 보고서는 국내외 사례와 기술 자료를 바탕으로 설문·수집 단계의 해킹 침투경로를 14 가지로 정리하고, 각 경로가 이미 발생했는지 또는 발생 가능성이 높은지를 구분하여 제시하였습니다. 아울러 클라우드 보안인증 체계를 중심으로 기술·인력·업무 절차에 걸친 대응 방안을 함께 담았습니다. 사고가 일어난 뒤의 대응보다 수집 단계에서의 선제적 예방이 국민의 피해를 줄이는 가장 확실한 길이라는 문제의식에서입니다.

이 보고서가 정책 담당자와 공공기관·기업의 실무자에게 실질적인 참고 자료가 되고, 국민의 개인정보를 지키기 위한 제도 개선 논의의 출발점이 되기를 바랍니다. 보고서 작성에 도움을 주신 모든 분께 깊이 감사드립니다.

2026 년 11 월

한국컨설팅산업재단 이사장 정 옥 래

발간기관 소개

개인정보보호진흥원

국민 개인정보 안심센터 — 현장을 진단하고, 실행할 수 있는 대안을 찾습니다

(재)한국컨설팅산업재단 부설

OUR ROLE

정보주체인 국민의 권리를 지키는 민간 공익 개인정보 보호 기구

- 컨설팅
- 교육
- 정책연구
- 포럼

개인정보보호진흥원은 (재)한국컨설팅산업재단의 대표 중점 사업으로, 컨설팅·교육·정책연구·포럼 활동을 종합적으로 수행합니다. 공공기관의 온라인 개인정보 수집 실태를 같은 기준으로 진단해 개선을 권고하고, 보안인증을 받은 도구가 현장에 자리 잡도록 지원하며, 현장의 근거를 정책 논의로 잇고 있습니다.

민간 공익기구입니다

진흥원은 정부 규제기관이 아니며, 조사 결과만으로 위법이나 유출을 단정하지 않습니다.

주요 사업 WHAT WE DO

01 · RESEARCH

실태조사·분석

SURE-CHECK로 공공기관의 온라인 신청·설문 화면을 같은 기준에서 진단하고, 결과를 공개해 개선을 권고합니다.

02 · EDUCATION

교육·웨비나

강화된 개인정보 보호법에 맞춰 공공기관·기업 실무자가 바로 적용할 수 있는 대응 교육을 운영합니다.

03 · DIFFUSION

인증도구 보급·확산

클라우드 보안인증(CSAP)을 받은 온라인 조사 도구를 공공기관·협단체 등이 부담 없이 쓰도록 무상 지원합니다.

04 · MONITORING

개인정보 지키미 모니터링단

국민이 직접 참여해 생활 속 개인정보 수집 화면을 살피는 모니터링단을 준비하고 있습니다.

일하는 방식 HOW WE WORK

STEP 1 · 진단

수집 화면 전수 진단

SURE-CHECK · 전문가 재확인

→

STEP 2 · 권고·지원

개선 권고와 실무 지원

교육·웨비나 · 인증도구 보급

→

STEP 3 · 정책 제언

현장 근거를 정책으로

정책연구 · 국정감사 자료 제공

개인정보보호진흥원

주요 활동

01 공공기관 온라인 개인정보 수집 실태 전수조사

1,347개	149건	98.7%	87.5%
공공기관 홈페이지	보안인증 없는 도구로	안전조치 안내 미흡	개선 권고 수용·개선
개인정보 수집 화면 진단	개인정보를 수집하던 설문	149건 중 147건	회신 40곳 중 35곳

조사 결과의 활용

- **정책연구** — 연구 보고서·정책 제언의 근거 자료
- **국정감사** — 국회 국정감사 자료 제공
- **결과 공개** — 기관별 개선 권고와 결과 공개

02 개인정보 보호 웨비나

강화된 개인정보 보호법에 맞춰 공공기관·기업 실무자가 무엇을 바꿔야 하는지 사례 중심으로 안내합니다. 설문·신청서 등 온라인 수집 단계의 안전조치와 보안인증 도구 활용 방법을 함께 다룹니다.

PARTICIPATION

860개+

웨비나 참가 신청 기관·기업

CONTACT

개인정보보호진흥원

서울특별시 송파구 양재대로71길 20-30, 2층

02-501-2906
전화

cs@kcf-korea.org
이메일

02-558-5146
팩스

www.kcf-korea.org/privacy-center
웹사이트

진흥원 바로가기

운영 법인

(재)한국컨설팅산업재단

Since 2010 · 공익법인 제4318호

"대한민국 지식서비스산업을 선도하는 공익법인" · 산업통상자원부 허가 재단법인
전국상업경진대회(NBO) 사무국 · 기업 컨설팅 교육 · 청소년 경영교육 · 개인정보보호진흥원
T 02-555-9091 · F 02-455-0090 · www.kcf-korea.org

※ 수치는 진흥원 공개 자료 기준(2026)

일러두기

- ○ 본 보고서는 설문·신청·수집 단계에서 발생할 수 있는 보안 위협을 국내외 사례와 AI 기술 동향에 근거하여 분석하고, 대응 방안을 제시하기 위하여 작성되었음
- ○ 본 보고서의 내용은 연구진의 분석 결과로서 발간기관의 공식 견해와 다를 수 있음
- ○ 본 보고서는 언론 보도와 정부 발표로 공개된 사고만을 분석 대상으로 하였으며, 공개되지 않은 사고를 포함할 경우 실제 피해 규모는 더 클 수 있음
- ○ 공격 기법은 위협의 이해에 필요한 수준으로만 기술하였으며, 실제 공격에 활용 가능한 세부 절차는 수록하지 않았음
- ○ 인용 자료는 각주와 참고문헌에 출처를 밝혔으며, 자료 기준일은 2026 년 11 월 7 일임

보고서명	AI 시대, 설문·신청·수집 단계의 보안 위협과 대응
발간번호	2026-11-01
발간일	2026 년 11 월 10 일
발간처	한국컨설팅산업재단 | 개인정보보호진흥원
문의	개인정보보호진흥원 02-501-2906 · cs@kcf-korea.org

본 보고서의 내용은 출처를 밝히고 인용할 수 있습니다.

목 차

요 약 ····· viii

I. 서 론 ····· 1
1. 추진 배경 ····· 2
2. 목적 및 범위 ····· 2
3. 분석 방법 및 한계 ····· 3
4. 보고서 구성 ····· 3

II. 설문·수집 단계의 보안 환경 변화 ····· 4
1. 설문·신청 양식의 구조적 특성 ····· 5
2. 공공부문 이용 실태 ····· 6
3. AI 기반 공격의 고도화 ····· 8

III. 설문·수집 단계 해킹 침투경로 분석 ····· 10
1. 분석 체계 ····· 11
2. 기관 직접 운영 시 해킹 침투경로 ····· 12
3. 외주(위탁) 수집 시 해킹 침투경로 ····· 19
4. 민간 기업·SaaS 해킹 침투경로 ····· 24
5. 소결 ····· 26

IV. 미인증 외부 설문도구의 취약 요인과 우선 점검 대상 ····· 27
1. 미인증 외부 설문도구의 6 대 기술적 취약 요인 ····· 28
2. 업무 특성에 따른 외주 업종별 우선 점검 대상 ····· 29

V. 대응 방안: 클라우드 보안인증 체계의 활용 ····· 32
1. 클라우드 보안인증 제도 개요 ····· 33
2. 제도 연혁 ····· 34
3. 보안인증 도구는 어떻게 해킹을 막는가 ····· 35
4. 미인증 도구 대비 통제 수준 비교 ····· 40
5. 적용 원칙: 공공 의무, 민간 적극 도입 ····· 41
6. 한계 및 보완 ····· 41

VI. 정책 제언 ····· 43
1. 도입 대안 비교 ····· 44
2. 단계별 추진 로드맵 ····· 45
3. 외주 계약 기준 개선 ····· 46
4. 제도 개선 과제 ····· 47
5. 대국민 안내 강화 ····· 48

VII. 결 론 ····· 49
1. 요약 및 시사점 ····· 50
2. 향후 과제 ····· 50

참고문헌 ····· 51

부록. 용어 정의 ····· 54

표 목차

<표 Ⅰ-1> 분석 범위 2
<표 Ⅰ-2> 발생 수준 구분 기준 3
<표 Ⅱ-1> 공공기관 개인정보 수집 설문의 도구 및 안내 실태(149 건 기준) 6
<표 Ⅱ-2> AI 를 활용하는 주요 악성코드(GTIG, 2025.11) 8
<표 Ⅱ-3> 2 단계 인증 방식별 계정 탈취 차단율 9
<표 Ⅲ-1> 해킹 침투경로 총괄 11
<표 Ⅳ-1> 6 대 취약 요인의 기술적 내용과 근거 28
<표 Ⅳ-2> 외주 업종별 위험 요인과 국내 사례 30
<표 Ⅴ-1> 공공기관용 추가 보호조치의 주요 항목 33
<표 Ⅴ-2> 보안인증 도구 전환 시 침투경로별 해킹 방어효과 40
<표 Ⅴ-3> 보안인증 설문 도구 도입 전 확인 항목 41
<표 Ⅵ-1> 단계별 추진 로드맵 45
<표 Ⅵ-2> 과업지시서·계약서 반영 문구(예시) 46
<표 Ⅵ-3> 국민 상담·신고 창구 48

그림 목차

<그림 Ⅱ-1> 설문·신청 양식의 구조적 특성 5
<그림 Ⅱ-2> AI 가 바꾼 공격 환경 9
<그림 Ⅲ-1> 설문·수집 단계 14 개 해킹 침투경로 종합도 11
<그림 Ⅲ-2> 해킹 침투경로 1 발생 구조 12
<그림 Ⅲ-3> 해킹 침투경로 2 발생 구조 13
<그림 Ⅲ-4> 해킹 침투경로 3 발생 구조 14
<그림 Ⅲ-5> 해킹 침투경로 4 발생 구조 15
<그림 Ⅲ-6> 해킹 침투경로 5 발생 구조 16
<그림 Ⅲ-7> 해킹 침투경로 6 발생 구조 17
<그림 Ⅲ-8> 해킹 침투경로 7 발생 구조 18
<그림 Ⅲ-9> 해킹 침투경로 8 발생 구조 19
<그림 Ⅲ-10> 해킹 침투경로 9 발생 구조 20
<그림 Ⅲ-11> 해킹 침투경로 10 발생 구조 21
<그림 Ⅲ-12> 해킹 침투경로 11 발생 구조 22
<그림 Ⅲ-13> 해킹 침투경로 12 발생 구조 23
<그림 Ⅲ-14> 해킹 침투경로 13 발생 구조 24
<그림 Ⅲ-15> 해킹 침투경로 14 발생 구조 26
<그림 Ⅳ-1> 미인증 외부 설문도구의 6 대 취약 요인 28
<그림 Ⅳ-2> 업무 특성에 따른 외주 업종별 우선 점검 대상 30
<그림 Ⅴ-1> 클라우드 보안인증 제도 연혁 34
<그림 Ⅴ-2> 미인증 무료 폼과 보안인증 도구의 방어 구조 비교 35
<그림 Ⅴ-3> 보안인증 도구의 6 겹 방어 장치 35
<그림 Ⅴ-4> 방어 장치 ① 계정 통제: 비밀번호가 새도 접근을 어렵게 함 36
<그림 Ⅴ-5> 방어 장치 ② 공개 범위·수정 통제: 설정 실수와 바꿔치기 차단 36
<그림 Ⅴ-6> 방어 장치 ③ 자료 보관·분리: 국내 공공 전용 영역에 보관 37
<그림 Ⅴ-7> 방어 장치 ④ 파일·첨부 처리: PC 감염 고리를 약화 37
<그림 Ⅴ-8> 방어 장치 ⑤ 감시·사고 대응: 조용한 침입을 드러냄 38
<그림 Ⅴ-9> 방어 장치 ⑥ 국가 검증 절차 38
<그림 Ⅴ-10> 해킹 침투경로별 방어 장치와 해킹 방어효과 39
<그림 Ⅴ-11> 미인증 무료 폼과 보안인증 도구의 통제 수준 비교 40
<그림 Ⅵ-1> 수집 도구 전환 대안 비교 44
<그림 Ⅵ-2> 외주 계약 조건의 적정성 판단 46
<그림 Ⅵ-3> 대국민 행동 수칙 10 가지 48

요 약

추진 배경	□ **(대국민 접점)** 설문·신청 양식(폼)은 거의 모든 기관·기업이 상시 운영하며, 불특정 외부인의 입력과 파일을 의도적으로 수신하는 구조적 특성을 가짐 □ **(실태)** 2026 년 공공기관 1,347 곳 진단 결과, 137 개 기관이 개인정보를 수집하는 설문 149 건을 보안인증을 받지 않은 외부 도구로 운영함 □ **(위협 환경)** 2025 년 이후 공격 작업의 80~90%를 AI 가 수행한 사례가 확인되는 등, 다수·분산된 진입점을 동시에 공격할 수 있는 환경이 형성됨
분석 결과	□ **(해킹 침투경로)** 기관 직접 운영 7 개, 외주(위탁) 5 개, 민간·SaaS 2 개 등 14 개 해킹 침투경로를 도출함 ○ 발생 수준: 핵심 단계 국내 확인 8 개, 해외 확인 1 개, 발생 가능성 높음(선제 통제 필요) 5 개 □ **(단계별 발생)** 폼에서 시작하여 내부 서버까지 장악된 공개 사례는 없으나, 해당 경로의 각 단계(악성 파일 감염, 인증정보 탈취, 원격접속을 통한 내부 침투)는 국내에서 모두 발생함 □ **(피해 확대 요인)** 외주업체의 잔존 자료(공직자 10 만여 명), 다수 고객사 공용 SaaS(11 만여 기업 이용 ERP, 고객사 22 곳 서비스) 침해가 피해를 확대함 □ **(구조적 원인)** 미인증 외부 폼의 취약성은 서비스 자체의 보안 수준보다 기관 보안 통제 밖에 있다는 구조에서 비롯됨(6 대 취약 요인)
정책 제언	□ **(수집 도구 전환)** 개인정보를 수집하는 폼은 클라우드 보안인증 도구로 전환 — 공공은 의무 이행 점검 강화, 민간은 적극 도입 유도 ○ 확인 항목을 갖춘 인증 도구는 12 개 침투경로에 대응하는 통제수단을 제공하며, 10 개는 크게 줄이거나 차단할 수 있는 것으로 판단됨(연구진 판단) □ **(외주 계약)** 보안인증 도구 사용과 파기 확인을 계약 조건으로 반영하되, 기관 계정 제공 등 부담 완화 장치 병행 □ **(제도 개선)** 실태평가·보호수준 평가 항목 반영, 교육현장 예외 영역의 최소 계정 보안 기준 마련, 공동 활용 모델 지원, AI 기능 평가 기준 마련 □ **(대국민 안내)** 국민 행동 수칙 10 가지와 상담·신고 창구 보급

핵심 판단	**설문·신청 양식(폼)에서 시작하여 내부 서버까지 장악된 공개 사례는 아직 확인되지 않았으나, AI 해킹 기술의 발전을 고려할 때 충분히 발생 가능하며, 선제적 예방이 반드시 필요함**

Part 1.

서 론

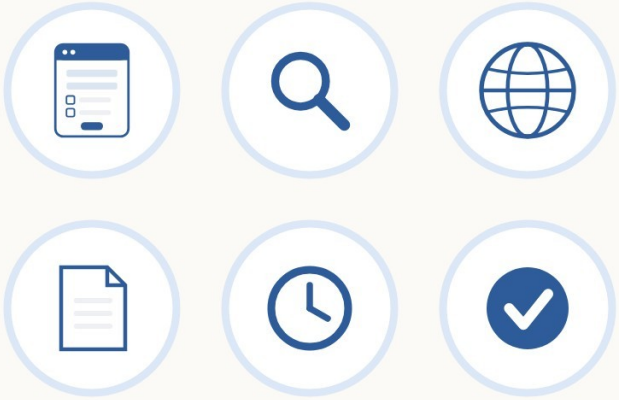
Introduction

01 추진 배경

02 목적 및 범위

03 분석 방법 및 한계

04 보고서 구성



01 추진 배경

□ **(사고 양상의 변화)** 2026 년 하반기 공공부문에서 기관 통제 밖의 외부 서비스·계정·업체를 경유한 개인정보 사고가 잇따라 발생함

○ 공군 1 호기 탑승자 168 명 명단이 약 5 개월간 외부 사이트에 노출되었으며, 외교부 보안 용역업체가 악성코드 검사 사이트에 원본 파일을 업로드한 정황이 조사 중임[1]

○ 국민권익위원회 교육 사이트의 수탁사가 서버 교체 후 옛 서버의 회원정보를 파기하지 않아 공직자 10 만 4,139 명의 정보가 유출됨[2]

○ 기업용 ERP 사업자 더존비즈온이 침해되어 고객사 임직원 정보의 유출 가능성이 제기되었고, 정부는 이를 '중대한 사고' 로 판단하여 민관합동조사단을 구성함[3]

□ **(공통 요인)** 사고의 공통점은 공격 기법의 정교함보다 **기관이 통제하지 못하는 곳에 국민의 정보가 놓여 있었다는 점**임

○ 설문·신청·접수는 국민의 정보가 기관으로 유입되는 첫 단계로, 이 단계가 기관 통제 밖에서 운영될 경우 이후 단계의 보안조치로는 이미 유출된 정보를 회복할 수 없음

□ **(AI 공격의 고도화)** 2025 년 이후 AI 가 공격 작업의 상당 부분을 자동 수행하는 사례가 확인되면서, 다수·분산 운영되는 설문·신청 양식이 대규모 공격의 진입 경로로 악용될 가능성이 커짐

02 목적 및 범위

□ **(목적)** 설문·신청·수집 단계를 경유하는 해킹 침투경로를 운영 형태별로 체계화하고, 실제 사례와 AI 기술 동향에 근거하여 발생 수준을 평가하며, 기술·제도적 대응 방안을 제시함

□ **(범위)** 운영 형태를 기관 직접 운영, 외주(위탁) 수집, 민간 기업·SaaS 의 세 영역으로 구분하여 총 14 개 해킹 침투경로를 분석함

<표 Ⅰ-1> 분석 범위

구분	상황	분석 대상
기관 직접 운영	기관 담당자가 보안인증을 받지 않은 외부 설문도구로 설문·신청을 받아 홈페이지·SNS 에 게시	침투경로 1~7
외주(위탁) 수집	수탁업체가 자체 계정·도구로 수집하고 결과 자료를 기관에 납품	침투경로 8~12
민간 기업·SaaS	기업이 외부 폼이나 다수 고객사 공용 SaaS 로 고객·임직원 정보를 수집·보관	침투경로 13~14

자료: 연구진 작성

[1] MBC, 「[단독] "'1 호기 명단' , 보안 업체서 고유 식별값 대신 원본 파일 올려"」, 2026.11.5. ; 동아일보, 대통령 순방단 개인정보 유출 보도, 2026.11.3.
[2] 경향신문, 「[단독]10 만명 공직자 정보 유출…"파기 완료" 위탁업체 1 년 반 허위 보고, 권익위는 몰랐다」, 2026.10.21.
[3] 뉴스 1, 「토종 1 위 ERP 더존비즈온 해킹… 고객사 민감정보 유출 가능성」, 2026.10.26. ; 보안뉴스, 「[더존비즈온 사태] 급여 계좌부터 가족 주민번호까지... 더존비즈온 해킹이 '중대 사고' 인 이유」, 2026.11.2.

03 분석 방법 및 한계

□ **(자료)** 국내외 보안기업·플랫폼사의 위협 분석 보고서, 학술 논문, 감독기관 처분 자료, 국회 제출 자료를 인용한 언론 보도를 수집하였으며, 인용 자료는 모두 원문을 직접 확인함(자료 기준일: 2026.11.7.)

□ **(발생 수준 구분)** 각 경로를 이미 발생한 위협과 발생이 예상되는 위협으로 구분하기 위해 3 단계 발생 수준을 적용함

<표 Ⅰ-2> 발생 수준 구분 기준

발생 수준	정의	판단 근거
국내 발생	해당 경로의 핵심 단계가 국내에서 실제로 확인된 위협	사고 보도, 감독기관 처분, 정부 발표
해외 발생	해외에서 실제로 확인된 위협 또는 실제 서비스에서 확인·수정된 같은 원리의 취약점	해외 사고 분석, 취약점 공개 자료
발생 가능성 높음	공개 사례는 없으나 관련 기법이 이미 확인되었고, 피해 규모를 고려할 때 선제 통제가 필요한 위협	단계별 발생 사례와 기술 동향의 결합(확률 추정이 아님)

자료: 연구진 작성

※ '국내 발생'·'해외 발생'은 해당 경로의 핵심 단계가 확인되었다는 뜻이며, 모든 사고가 설문 도구에서 시작되었다는 뜻은 아님. 각 경로의 '발생 사례'에서 확인된 범위를 구분하여 기술함

□ **(한계)** 본 보고서는 언론 보도와 정부 발표로 공개된 사고만을 분석 대상으로 하였음

- ○ 공개되지 않은 사고까지 포함할 경우 실제 피해 규모는 본 보고서의 분석보다 클 수 있음
- ○ 공격 기법은 위협의 이해에 필요한 수준으로만 기술하였으며, 실제 공격에 활용 가능한 세부 절차는 수록하지 않음

04 보고서 구성

□ II 장은 설문·수집 단계의 보안 환경 변화를, III 장은 14 개 해킹 침투경로를, IV 장은 미인증 외부 설문도구의 기술적 취약 요인과 외주 업종별 위험도를 분석함

□ V 장은 대응 수단으로서 클라우드 보안인증 체계를 검토하고, VI 장은 단계별 추진 로드맵과 제도 개선 과제를, VII 장은 결론을 제시함

Part 2.

설문·수집 단계의 보안 환경 변화

Changing Security Landscape

01 설문·신청 양식의 구조적 특성

02 공공부문 이용 실태

03 AI 기반 공격의 고도화



01 설문·신청 양식의 구조적 특성

□ **(편재성)** 설문·신청 양식(이하 ‘폼’)은 특정 부서의 업무가 아니라 채용, 교육, 행사, 민원, 공모전, 만족도 조사 등 거의 모든 부서가 연중 상시 운영하는 대국민 접점임

□ **(개방성)** 폼은 기관 정보시스템 가운데 로그인 없이 **불특정 외부인의 입력을 의도적으로 수신**하는 거의 유일한 창구임

□ **(다양성)** 텍스트·숫자뿐 아니라 파일까지 수신하므로, 공격자 입장에서 정상 업무로 위장한 진입이 용이함



<그림 II-1> 설문·신청 양식의 구조적 특성

자료: 연구진 작성

□ **(시사점)** 폼은 수가 많고 곳곳에 분산되어 있어 개별 관리가 어렵고, AI 를 활용한 대량·자동화 공격의 우선 표적이 될 수 있으므로 **외부 침입에 대한 선제적 예방**이 우선되어야 함

02 공공부문 이용 실태

□ **(실태 진단)** (재)한국컨설팅산업재단 부설 개인정보보호진흥원과 국회 정무위원회 박상혁 의원실은 2026년 8 월 21 일부터 10 월 5 일까지 공공기관 1,347 곳의 공개 설문·신청서를 진단함[4]

○ 개인정보를 수집하는 것으로 확인되어 결과를 통보한 137 개 기관의 설문 149 건이 모두 보안인증을 받지 않은 외부 도구로 운영되고 있었음

<표 II-1> 공공기관 개인정보 수집 설문의 도구 및 안내 실태(149 건 기준)

항목	결과
사용 도구	구글폼 90 건(60.4%), 네이버폼 47 건(31.5%), 모아폼 11 건(7.4%), 서베이몽키 1 건(0.7%)
민감·고위험 정보	주민등록번호 3 건, 건강·장애 정보 8 건(1 건은 둘 다 해당) 등 10 건(6.7%)
안내 미흡률(공개 화면 기준)	안전조치 98.7%, 위탁 96.0%, 국외이전 66.4%, 동의 거부권 61.1%
기관 유형	출연·출자기관 58 건, 지방자치단체 56 건(전체의 76.5%)
결과 통보 후	40 개 기관 회신, 이 중 35 곳(87.5%)이 수용·개선(개선 완료 16, 수용 19)

자료: (재)한국컨설팅산업재단 부설 개인정보보호진흥원·국회 박상혁 의원실(2026), 보도자료·붙임 재구성

참고 II-1 실태조사 방법과 해석상 유의점

- **(대상)** 개인정보 보호수준 진단 대상 1,464 개 기관 중 홈페이지를 운영하는 1,347 개 기관의 공개 설문·신청서 링크
- **(방법)** 진흥원의 자동진단도구(SURE CHECK)로 공개 링크를 진단한 뒤 전문가가 재확인. 도구별 CSAP 인증 여부는 한국인터넷진흥원 인증 현황과 대조(구글은 클라우드 인프라(GCP)만 인증, 네이버의 다른 공공용 상품 인증은 네이버폼에 적용되지 않음)
- **(분석 단위)** 개인정보를 수집하는 것으로 확인되어 결과 통보 공문을 보낸 137 개 기관의 설문 149 건
- **(지표의 의미)** '안내 미흡' 은 공개된 설문 화면의 입력 문항과 안내 내용을 기준으로 판단한 것으로, 기관 내부의 계정 보호·접속 기록·계약 내용 등 실제 보안조치의 유무를 확인한 것은 아님. 응답자료는 열람하거나 수집하지 않음
- **(회신 결과)** 87.5%는 회신한 40 개 기관 중 35 곳(개선 완료 16 곳, 수용 19 곳)의 비율이며, 통보 기관 전체(137 개)의 개선율이 아님. 5 곳은 사실관계 소명·법령 해석 의견을 제출함

□ **(감독기관 입장)** 개인정보보호위원회는 수탁사의 외부 설문도구 사용이 재위탁에는 해당하지 않으나, 외부 도구를 사용하더라도 최소 수집, 공개 설정 금지, 목적 달성 시 파기 등 **안전조치 책임은 이용기관에 있다**고 안내함(2026.10.16.)[5]

○ 다만 개인정보 보호 전담기관인 개인정보보호위원회의 위탁사업에서도 교육 신청을 구글폼으로 받은 사실이 보도됨[6]

[4](재)한국컨설팅산업재단 부설 개인정보보호진흥원·국회 박상혁 의원실, 「공공기관 온라인설문 개인정보 수집실태」 보도자료 및 붙임 조사결과(조사기간 2026.8.21.~10.5.).
[5]개인정보보호위원회, 「외부 설문도구 이용 시 개인정보 처리 준수 사항에 대해 보다 명확히 안내하겠습니다」 보도참고자료, 2026.10.16.
[6]전자신문, 「보안인증 없는 구글폼…개보위 사업에 쓰였다」, 2026.10.15.

□ **(계정 관리 실태)** 기관 업무에 개인 계정이 사용되거나, 기관 계정이 대규모로 탈취되는 사례가 확인됨

○ 청와대 국민사서함은 관리자 1 명의 개인 구글 계정으로 3 만 8,741 건을 접수하였고, 내려받기·공유 이력은 “파기하여 확인할 수 없다” 고 답변함[7]

○ 2026 년 10 월 6 개 지역 학교의 교육용 구글 계정 11 만 2,890 개에서 비정상 로그인과 비밀번호 무단 변경이 확인됨[8]

[7]경북도민일보, 「천하람 "국민사서함 3 만 8000 건 답변도 없이 폐기"」, 2026.10.29.
[8]뉴시스, 「6 개 지역서 학교 구글 계정 11 만개 해킹…"비번 360 만개 변경 완료"」, 2026.10.22.

03 AI 기반 공격의 고도화

□ **(공격 자동화)** AI 에이전트가 침투 작업의 대부분을 수행하는 단계에 진입함

○ Anthropic 은 국가 배후로 추정되는 조직이 AI 코딩 도구를 자동화 도구로 활용하여 기술기업·금융기관·정부기관 등 약 30 곳에 침투를 시도하였고, 공격 작업의 **80~90%를 AI 가 수행**하였다고 발표함(2025.11)[9]

- 사람은 캠페인당 4~6 회의 주요 결정에만 개입하였으며, 일부 공격은 성공함. 다만 AI 가 계정정보를 지어내는 등의 한계도 보고됨

○ 한 범죄자가 AI 에이전트로 정부·의료기관 등 최소 17 곳의 정찰과 침투를 자동화하고, 탈취 자료 선별과 협박 금액 결정까지 AI 에 맡긴 사례가 공개됨(2025.8)[10]

□ **(AI 내장 악성코드)** 실행 중 대형언어모델(LLM)에 질의하여 행동을 바꾸는 악성코드가 실제 공격에서 확인됨[11]

<표 II-2> AI를 활용하는 주요 악성코드(GTIG, 2025.11)

명칭	상태	동작 개요
PROMPTSTEAL	실전 사용	LLM 에 시스템 정보·문서 수집 명령을 생성하게 한 뒤 실행하고 결과를 외부로 전송
QUIETVAULT	실전 사용	개발자 인증 토큰을 탈취하고, 감염 PC 의 AI 명령줄 도구로 다른 비밀정보를 탐색
PROMPTFLUX	실험·개발	LLM API 로 자기 코드를 재작성하여 탐지 회피 시도

자료: Google Threat Intelligence Group(2025.11.5.)

□ **(미끼의 고도화)** 생성형 AI 로 가짜 화면과 맞춤형 문구, 딥페이크를 손쉽게 제작함

○ 공격자가 생성형 AI 웹 제작 도구로 실제 로그인 화면을 문장 몇 줄만으로 복제한 사례가 확인됨(2025.7)[12]

○ 북한 배후 추정 조직(김수키)이 챗 GPT 로 만든 딥페이크 군무원 신분증 이미지를 미끼로 군 관계 기관을 공격함. 국내에서 생성형 AI 딥페이크가 공격에 사용된 첫 확인 사례임(2025.7)[13]

□ **(AI 비서의 공격면화)** 메일·문서 등 AI 가 읽는 자료에 명령을 숨겨 AI 비서를 조종하는 간접 프롬프트 인젝션이 실제 서비스에서 확인됨

○ EchoLeak(Microsoft 365 Copilot, 2025)[14], GeminiJack(Gemini Enterprise, 2025.12)[15]

○ 구글은 이 위협이 한 번 해결하고 끝나는 문제가 아니라 지속적 대응이 필요한 위협이라고 밝힘(2026.4)[16]

□ **(계정·세션 탈취의 산업화)** 2 단계 인증이 적용되지 않은 계정이 대량으로 악용되고, 2 단계 인증을 우회하는 세션 탈취도 확산됨

○ (미적용) 스노우플레이크 고객사 데이터 탈취 사건(2024)에서 공격에 사용된 계정의 79.7%는 이미 유출된 자격증명이었고, 피해 계정에는 2 단계 인증이 적용되지 않았음[17]

[9] Anthropic, "Disrupting the first reported AI-orchestrated cyber espionage campaign", 2025.11.13.
[10] Anthropic, "Detecting and countering misuse of AI: August 2025", 2025.8.27.
[11] Google Threat Intelligence Group, "GTIG AI Threat Tracker: Advances in Threat Actor Usage of AI Tools", 2025.11.5.
[12] Okta Threat Intelligence, "Okta observes v0 AI tool used to build phishing sites", 2025.7.1.
[13] MBC, 「북한 배후 해킹그룹, 챗 GPT 로 군 신분증 위조··피싱 공격 시도」, 2025.9.15.
[14] P. Reddy, A. S. Gujral, "EchoLeak: The First Real-World Zero-Click Prompt Injection Exploit in a Production LLM System", arXiv:2509.10540, 2025.9.
[15] Noma Security, "GeminiJack: the Google Gemini zero-click vulnerability leaked Gmail, Calendar and Docs data", 2025.12.8.
[16] Google, "Google Workspace's continuous approach to mitigating indirect prompt injections", 2026.4.2.
[17] Mandiant(Google Cloud), "UNC5537 Targets Snowflake Customer Instances for Data Theft and Extortion", 2024.6.10.

○ (우회) 정보탈취 악성코드가 만료된 구글 로그인을 되살리는 기능을 탑재하였고[18], 로그인을 중계하여 2 단계 인증 이후의 세션을 가로채는 피싱으로 1 만여 개 조직이 공격받음[19]

<표 II -3> 2 단계 인증 방식별 계정 탈취 차단율

방식	자동화 공격	대량 피싱	표적 공격
문자(SMS) 코드	100%	96%	76%
휴대폰 로그인 확인 알림	100%	99%	90%
보안키	-	-	보안키만 사용한 이용자 중 표적 피싱 피해자 0 명

자료: Google Security Blog(2019.5.17.)



<그림 II -2> AI 가 바꾼 공격 환경

자료: 연구진 작성

□ **(시사점)** AI 는 새로운 침투 경로를 만들기보다 **기존 공격의 비용을 낮추고 속도와 규모를 키우는** 방향으로 작용함

○ 과거에는 공격 효율이 낮아 방치되던 소규모·분산 진입점까지 동시에 공격할 수 있게 되었으며, 다수 기관에 흩어진 설문·신청 양식이 대표적인 대상임

[18] CloudSEK, "Compromising Google Accounts: Malwares Exploiting Undocumented OAuth2 Functionality for session hijacking", 2023.12.29.
[19] Microsoft Threat Intelligence, "From cookie theft to BEC: Attackers use AiTM phishing sites as entry point to further financial fraud", 2022.7.12.

Part 3.

설문·수집 단계 해킹 침투경로 분석

Intrusion Path Analysis

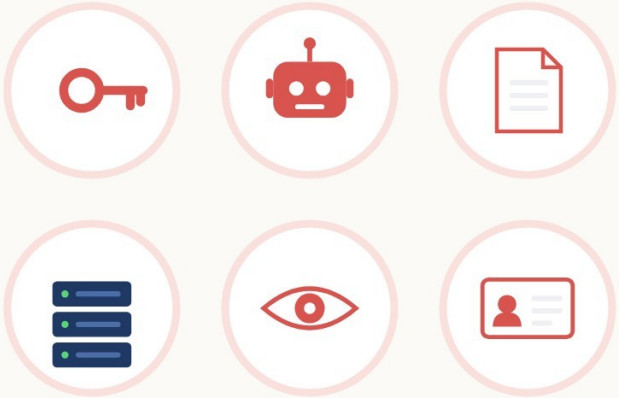
01 분석 체계

02 기관 직접 운영 시 해킹 침투경로

03 외주(위탁) 수집 시 해킹 침투경로

04 민간 기업·SaaS 해킹 침투경로

05 소결



01 분석 체계

□ **(구조)** 국민·고객의 입력이 폼을 거쳐 담당자 계정, 외주업체 계정·서버, SaaS 플랫폼에 저장되고, 담당자 PC·AI 비서·원격접속을 거쳐 기관 내부로 연결되는 흐름을 기준으로 공격 개입 지점을 도출함



<그림 III-1> 설문·수집 단계 14 개 해킹 침투경로 종합도

자료: 연구진 작성

<표 III-1> 해킹 침투경로 총괄

침투 경로	위협 내용	발생 수준	핵심 대응
1	공개 설정 오류에 의한 응답 노출	국내 발생	공개 범위 관리자 통제
2	폼 소유 계정 탈취에 의한 응답 일괄 유출	국내 발생	기관 계정, 피싱 저항형 인증
3	탈취 계정을 통한 공식 폼 변조	발생 가능성 높음	수정 이력 관리, 2 인 확인
4	기관 사칭 가짜 폼	해외 발생	기관 고유 주소 공지
5	응답 내 숨은 명령에 의한 AI 비서 조종	발생 가능성 높음	외부 응답 분리 분석
6	첨부파일 → 담당자 PC → 내부 서버	발생 가능성 높음	격리 검사, 원격접속 2 차 인증
7	유출 명단을 활용한 AI 표적 피싱	발생 가능성 높음	최소 수집, 기한 내 파기
8	외주업체 PC·관리자 계정 탈취	국내 발생	기관 계약 계정, 2 단계 인증
9	사업 종료 후 미파기 자료 유출	국내 발생	파기 증빙·현장 확인
10	외주업체의 외부 웹서비스 원본 업로드	국내 발생	외부 업로드 금지 계약
11	납품 파일·연동 앱 승인을 통한 침투	발생 가능성 높음	서비스 내 열람, 승인 권한 제한
12	외주 원격접속 계정을 통한 내부망 침입	국내 발생	2 차 인증·IP 제한
13	SaaS 플랫폼 침해의 고객사 전체 확산	국내 발생	데이터 분리·파기 기준 확인

침투 경로	위협 내용	발생 수준	핵심 대응
14	계정 거래·전화 사칭을 통한 대량 반출	국내·해외 발생	연동 앱 승인 관리자 한정

자료: 연구진 작성

□ **(종합)** 14 개 해킹 침투경로 중 9 개는 국내 또는 해외에서 이미 발생하였고, 5 개는 공개 사례는 없으나 필요한 기술과 재료가 모두 확인된 경로임

02 기관 직접 운영 시 해킹 침투경로

□ 담당자가 무료 외부 폼으로 설문·신청을 받는 경우, 응답과 첨부파일은 기관이 아닌 **담당자 개인 계정**에 축적되며 기관은 접근·공유·파기 이력을 통제하지 못함

해킹 침투경로 1 | **공개 설정 오류에 의한 응답 노출** | **국내 발생**



<그림 III-2> 해킹 침투경로 1 발생 구조

자료: 연구진 작성

□ **(발생 구조)** '결과 요약 보기' 를 활성화하거나 응답 시트의 공유 범위를 제한하지 않을 경우, 응답 제출자나 링크 보유자가 다른 응답자의 정보를 열람할 수 있음

○ 외부 공격 없이 설정 오류만으로 유출이 발생하며, 노출 정보는 캡처·재배포로 회수가 불가능함

□ **(발생 사례)** 개인정보보호위원회는 2021~2025 년 외부 설문도구 응답 노출과 관련하여 8 건의 과태료를 의결함[20]

○ 음악방송 방청객 모집 폼(약 33 분간 2,716 명 노출), 크리에이터 가입 신청 폼(11 일간 주민등록번호·계좌번호 노출) 등

○ '서비스 제공자 서버 오류' 주장은 받아들여지지 않았으며, 처분은 폼을 만든 기관·기업에 부과됨

□ **(AI 영향)** 공개된 폼 주소를 자동화 도구로 대량 점검할 경우 설정 오류의 발견 속도가 빨라질 수 있음

□ **(대응 방향)** 공개 범위를 기관 관리자가 일괄 통제하는 도구 사용, 게시 전 별도 계정을 통한 노출 점검, 주민등록번호·건강정보 등 민감정보 수집 금지

[20] 이현섭(법무법인 세움), 「구글폼 응답이 다른 응답자에게 보였다면 과태료 대상일까요? — 결정문 8 건의 기준」, 2026.10.19.

해킹 침투경로 2 | **폼 소유 계정 탈취에 의한 응답 일괄 유출** | **국내 발생(계정 침해)**



<그림 III-3> 해킹 침투경로 2 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 폼·응답·첨부파일은 폼을 만든 사람의 계정에 귀속되므로, 해당 계정이 피싱이나 정보탈취 악성코드로 탈취되면 누적된 응답 전체가 유출됨

□ **(발생 사례)** 학교 교육용 구글 계정 11 만 2,890 개에서 비정상 로그인·비밀번호 무단 변경이 확인되었으며, 대전에서는 하룻밤에 7 만여 개가 변경되고 졸업생·퇴직자 계정 정리 규정도 없었음(2026.10)[21]

- ○ 다만 보도로 확인된 것은 계정 침해 단계까지이며, 해당 계정의 폼 응답이 일괄 반출되었는지는 확인되지 않음
- ○ 이 계정들은 「국가 사이버보안 기본지침」이 도입 가능 목록 이용 의무의 예외로 둔 '교육현장' 에서 운영되던 것으로, 예외 영역에도 최소한의 계정 보안 기준이 필요함을 보여 줌(V 장 5 절)[22]
- ○ 북한 배후 추정 조직은 국세청 통지서로 위장한 메일로 네이버 가짜 로그인 화면을 띄워 계정 탈취를 시도함(2025.2)[23]

□ **(AI 영향)** 탈취된 대량 계정 가운데 공공기관 담당자 계정을 자동으로 선별하고, 개인별 맞춤 피싱으로 탈취 비용을 낮춤

□ **(대응 방향)** 기관 소유 계정으로 운영, 보안키·패스키 등 피싱 저항형 인증 적용[24], 로그인·내려받기 기록 관리, 인사이동·퇴직 시 권한 즉시 회수

[21]뉴시스, 「6 개 지역서 학교 구글 계정 11 만개 해킹…"비번 360 만개 변경 완료"」, 2026.10.22. ; 뉴시스, 「대전 학교 구글 비번 7 만개 '무단 변경' … 졸업생·퇴직자도 피해 가능성」, 2026.10.13.
[22]국가정보원, 「국가 사이버보안 기본지침」(2026.5.1.) 제 2 조, 제 24 조의 3·제 24 조의 4.
[23]보안뉴스, 「[단독] 北김수키, 국세청·네이버 사칭 공격 활개..계정 도용 주의보!」, 2025.3.2.
[24]Google Security Blog, "New research: How effective is basic account hygiene at preventing hijacking", 2019.5.17.

해킹 침투경로 3 **탈취 계정을 통한 공식 폼 변조** **발생 가능성 높음**



<그림 III-4> 해킹 침투경로 3 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 계정을 장악한 공격자가 게시 중인 공식 폼의 문항·안내문·완료 화면 링크를 변조하여, 기관 홈페이지 링크로 접속한 국민에게 계좌·인증번호 등을 요구할 수 있음

□ **(발생 가능성 판단)** 공개 피해 사례는 없으나 다음 요건이 이미 충족됨

- ○ (재료) 폼 소유 계정의 대규모 탈취가 국내에서 발생함(침투경로 2)
- ○ (구조) 폼 소유자는 언제든 문항과 링크를 수정할 수 있고, 변경 내용은 같은 주소로 즉시 공개됨
- ○ (기술) 생성형 AI 로 기관의 문체와 화면을 모방하는 것이 용이해짐[25]

□ **(대응 방향)** 수정 이력·알림이 기관에 남는 도구 사용, 게시 중 폼 수정 시 2 인 확인, “비밀번호·인증번호·계좌 비밀번호를 묻지 않음” 을 사전 공지

[25] Okta Threat Intelligence, "Okta observes v0 AI tool used to build phishing sites", 2025.7.1.

해킹 침투경로 4 기관 사칭 가짜 폼 **해외 발생**



<그림 III-5> 해킹 침투경로 4 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 공격자가 무료 폼에 기관 명칭·로고를 넣은 가짜 신청서를 제작하여 문자·메일로 유포하며, 대형 포털 주소를 사용하므로 보안 필터와 이용자의 경계를 통과하기 쉬움

□ **(발생 사례)** 보안기업 Zimperium 은 미국 국세청(IRS)·은행·통신사 등 25 곳 이상을 사칭하여 비밀번호를 탈취하던 구글폼 265 개를 확인하였으며, 해당 폼은 평판 기반 탐지를 회피하고 피싱 목록 등재 후에도 수개월간 유지됨[26]

○ 구글폼 알림 메일이 구글 서버에서 발송되어 스팸 필터를 통과하기 쉬운 점이 사기에 악용됨(2025.7)[27]

□ **(AI 영향)** 생성형 AI 로 실제와 동일한 화면과 문구를 단시간에 대량 제작할 수 있음[28]

□ **(대응 방향)** 기관 고유 도메인(OO.go.kr 등)에서 신청 접수 및 공식 접수 경로 공지, 사칭 폼 발견 시 사업자 신고와 홈페이지 경고

[26]Forbes(Davey Winder), "Google Forms Used In Password-Stealing Spree: What You Need To Know"(Zimperium 연구 인용), 2020.11.3.
[27]Kaspersky, "Beware of Google Forms bearing crypto gifts", 2025.7.24.
[28]Okta Threat Intelligence, "Okta observes v0 AI tool used to build phishing sites", 2025.7.1.

해킹 침투경로 5 **응답 내 숨은 명령에 의한 AI 비서 조종** **발생 가능성 높음**



<그림 III-6> 해킹 침투경로 5 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 응답자로 위장한 공격자가 자유 응답란에 AI 용 명령을 숨겨 제출하고, 담당자가 AI 비서로 응답을 요약·분석하는 순간 명령이 실행되어 같은 계정의 메일·문서가 외부로 전송될 수 있음

□ **(발생 가능성 판단)** 폼 응답을 통한 공개 사례는 없으나, 같은 원리의 취약점이 실제 서비스에서 확인·수정됨 (실제 피해 사례는 확인되지 않음)

- ○ EchoLeak: 조작된 메일 한 통으로 Microsoft 365 Copilot 자료가 사용자 조작 없이 유출될 수 있었음[29]
- ○ GeminiJack: 공유 문서·일정 초대에 숨긴 명령으로 Gemini Enterprise 가 메일·문서를 외부로 전송할 수 있었으며, 구글이 구조 변경으로 조치함(2025.12)[30]
- ○ 폼 응답은 메일·공유 문서와 같이 누구나 작성할 수 있는 외부 입력이라는 점에서 동일한 위험 구조를 가짐

□ **(대응 방향)** 외부 응답은 메일·문서 접근 권한이 없는 별도 환경에서 분석, AI 결과의 외부 링크·이미지 자동 로딩 차단, 최종 판단은 사람이 수행

[29] P. Reddy, A. S. Gujral, "EchoLeak: The First Real-World Zero-Click Prompt Injection Exploit in a Production LLM System", arXiv:2509.10540, 2025.9.
[30] Noma Security, "GeminiJack: the Google Gemini zero-click vulnerability leaked Gmail, Calendar and Docs data", 2025.12.8.

해킹 침투경로 6 | **첨부파일 → 담당자 PC → 내부 서버** | **발생 가능성 높음**



<그림 III-7> 해킹 침투경로 6 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 공모전·증빙 접수 폼으로 업무 문서로 위장한 파일이 유입되고, 담당자 PC 감염 후 저장된 인증정보로 원격접속을 거쳐 내부 서버에 접근할 수 있음

□ **(발생 가능성 판단)** 폼에서 시작하여 내부 서버까지 이어진 공개 사례는 없으나, **경로를 구성하는 각 단계는 국내에서 모두 발생함**

○ (PC 감염) 금융 문서로 위장한 바로가기 파일이 정찰 후 원격 조종 도구를 설치하고, 명령·유출에 GitHub·Dropbox 등 정상 서비스를 이용함(2026.9)[31]

○ (인증정보 → 내부 서버) 해커가 공무원 인증서와 비밀번호를 확보하여 2022 년 9 월부터 2025 년 7 월까지 원격접속시스템을 통과해 온나라시스템 자료를 열람함. 국정원은 정상 경로로 은밀히 진행되는 해킹은 기존 관제로 포착하기 어렵다고 밝힘[32]

○ (AI 가세) AI 를 내장한 악성코드가 감염 PC 에서 비밀정보를 탐색하는 사례가 해외에서 확인됨[33]

□ **(대응 방향)** 파일 업로드 최소화 및 형식·크기 제한, 수신 파일의 격리 환경 검사·열람, 원격접속 2 차 인증과 이상 징후 상시 감시, 업무 PC 의 개인 계정 사용 금지

핵심 판단	**설문·신청 양식(폼)에서 시작하여 내부 서버까지 장악된 공개 사례는 아직 확인되지 않았으나, AI 해킹 기술의 발전을 고려할 때 충분히 발생 가능하며, 선제적 예방이 반드시 필요함**

[31]이스트시큐리티 ESRC, 「기능별 C2 서버를 운용하는 Kimsuky 그룹의 새로운 LNK 악성코드 등장」, 2026.9.9.
[32]보안뉴스, 「[대한민국 털렸다] '프랙' 보고서 사실이었다...행안부 온나라 시스템 등 해킹 확인」, 2025.10.17.
[33]Google Threat Intelligence Group, "GTIG AI Threat Tracker: Advances in Threat Actor Usage of AI Tools", 2025.11.5.

해킹 침투경로 7 유출 명단을 활용한 AI 표적 피싱 발생 가능성 높음



<그림 III-8> 해킹 침투경로 7 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 교육·행사 신청서에 축적된 공직자 이름·소속·직급·연락처가 유출되면, AI 로 개인별 맞춤 피싱 메일과 위조 신분증을 대량 생성하여 다른 기관 담당자를 공격할 수 있음

□ **(발생 가능성 판단)** 재료와 기술이 모두 국내에서 확인됨

- ○ (재료) 권익위 교육 사이트에서 공직자 10 만 4,139 명의 이름·생년월일·소속·직급·연락처가 유출됨(2026.9)[34]
- ○ (기술) 생성형 AI 딥페이크 신분증을 활용한 피싱이 국내에서 확인됨(2025.7)[35]
- ○ (경고) 더존비즈온 사고 이후 보안 전문가들은 유출 정보를 활용한 정교한 2 차 표적 공격을 경고함[36]

□ **(대응 방향)** 목적에 필요한 최소 항목만 수집, 목적 달성 시 즉시 파기 및 기록, 공직자 대상 신청은 보안인증 도구로 수집

[34]경향신문, 「[단독]10 만명 공직자 정보 유출…"파기 완료" 위탁업체 1 년 반 허위 보고, 권익위는 몰랐다」, 2026.10.21.
[35]MBC, 「북한 배후 해킹그룹, 챗 GPT 로 군 신분증 위조··피싱 공격 시도」, 2025.9.15.
[36]보안뉴스, 「[더존비즈온 사태] 급여 계좌부터 가족 주민번호까지... 더존비즈온 해킹이 '중대 사고'인 이유」, 2026.11.2.

03 외주(위탁) 수집 시 해킹 침투경로

□ 외주 구조에서는 국민의 정보가 **기관이 직접 확인할 수 없는 수탁업체의 계정과 서버**에 남으며, 개인정보보호법 제 26 조에 따라 위탁자는 수탁자를 관리·감독할 책임을 짐

해킹 침투경로 8 | **외주업체 PC·관리자 계정 탈취** | **국내 발생**



<그림 Ⅲ-9> 해킹 침투경로 8 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 외주업체 직원의 PC 나 관리자 계정 하나가 탈취되면 해당 업체가 수행하는 여러 기관·기업의 자료가 동시에 위험에 노출됨

□ **(발생 사례)** 콜센터·텔레마케팅 아웃소싱 업체 KS 한국고용정보는 관리자 계정을 탈취당해 상담사·직원·입사 지원자 4 만 875 명의 주민등록번호·계좌번호 등과 인사서류 5 만 건이 유출되었고, 해커는 다크웹 판매를 시도함[37]

○ 아이디·비밀번호만으로 외부에서 서버 접속이 가능하였고 파일 경로 검증도 이루어지지 않았으며, 과징금 35 억 3,700 만 원이 부과됨(2026.4)

○ 해외에서도 스노우플레이크 고객사 사건(2024)의 최초 감염은 계약자 PC 였으며, 약 165 개 조직이 통지를 받음[38]

□ **(대응 방향)** 외주업체의 기관 계약 계정 사용 및 2 단계 인증 의무화, 접속 IP 제한, 계약 종료 시 즉시 회수, 외주 PC 보안 점검의 계약 조건화

[37]미디어오늘, 「직원 가족·입사 지원자 개인정보 '탈탈' 털린 콜센터 업체」, 2026.4.23.
[38]Mandiant(Google Cloud), "UNC5537 Targets Snowflake Customer Instances for Data Theft and Extortion", 2024.6.10.

해킹 침투경로 9 사업 종료 후 미파기 자료 유출 국내 발생



<그림 III-10> 해킹 침투경로 9 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 사업 종료 후 수탁업체가 '파기 완료'를 보고하였으나 옛 서버·백업에 자료가 남아 있을 경우, 관리되지 않는 시스템이 공격 표적이 됨

□ **(발생 사례)** 권익위 교육 사이트 수탁사는 서버 교체 후 옛 서버의 회원정보를 지우지 않은 채 1년 반 동안 파기 항목을 '양호'로 보고하였고, 권익위의 점검은 업체 자체 점검에 의존함(2026.9)[39]

○ 같은 업체(맑은소프트)의 고객사 22곳에서 약 237만 건의 유출이 신고됨[40]

○ 더존비즈온 사고에서 서울시육아종합지원센터는 서비스 종료 후에도 데이터가 삭제되지 않아 유출 가능성을 통지함(2026.11)[41]

□ **(대응 방향)** 종료·이관 시 파기 증빙 및 현장 확인, 수집 단계부터 기관 계약 서비스를 사용하여 자료가 업체에 잔존하지 않도록 함

[39]경향신문, 「[단독]10만명 공직자 정보 유출…"파기 완료" 위탁업체 1년 반 허위 보고, 권익위는 몰랐다」, 2026.10.21.
[40]보안뉴스, 「맑은소프트 개인정보 유출 규모 237만건… 고객사 22곳 불똥」, 2026.10.13.
[41]보안뉴스, 「[더존비즈온 사태] 11월 5일 유출 의심 기업 현황… 서울시 육아종합지원센터 유출 가능성」, 2026.11.5.

해킹 침투경로 10 외주업체의 외부 웹서비스 원본 업로드 국내 발생



<그림 III-11> 해킹 침투경로 10 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 수탁업체가 파일 검사·변환·공유를 위해 검증되지 않은 외부 웹서비스에 원본을 업로드하면, 해당 서비스의 공개 정책에 따라 제 3 자가 열람할 수 있음

□ **(발생 사례)** 공군 1 호기 탑승자 168 명 명단이 약 5 개월간 외부 사이트에 노출되었으며, 정부는 외교부 보안 용역업체가 악성코드 검사 사이트에 고유 식별값 대신 원본 파일을 올린 정황을 조사 중임(2026.11)[42]

○ 보안 업무를 수행하는 업체조차 외부 도구 사용 시 정보가 기관 밖으로 유출될 수 있음을 보여 줌

□ **(대응 방향)** 계약서에 외부 웹서비스 원본 업로드 금지 명시, 업무 PC 의 외부 업로드 차단 등 유출 방지 통제, 기관 승인 도구만 사용

[42] MBC, 「[단독] "1 호기 명단", 보안 업체서 고유 식별값 대신 원본 파일 올려"」, 2026.11.5. ; 동아일보, 대통령 순방단 개인정보 유출 보도, 2026.11.3.

해킹 침투경로 11 납품 파일·연동 앱 승인을 통한 침투 발생 가능성 높음



<그림 III-12> 해킹 침투경로 11 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 감염된 외주 PC 에서 작성된 납품 파일이나 "자동 연동"을 명목으로 한 앱 승인 요청이 기관 환경으로의 침투 통로가 될 수 있음

□ **(발생 가능성 판단)** 납품 파일이 출발점인 공개 사례는 없으나 구성 기법은 확인됨

○ (연동 앱, 해외) IT 지원팀 사칭 전화로 직원이 악성 연동 앱을 승인하게 하여 고객관리(CRM) 자료를 대량 반출한 사례(UNC6040, 2025)[43]

○ (미끼 파일, 국내) 업무 문서로 위장한 악성 파일 공격이 지속 확인됨(2026.9)[44]

□ **(대응 방향)** 파일 전달 대신 기관 서비스 내 결과 열람, 수신 파일 격리 검사, 연동 앱 승인 권한의 관리자 한정

[43] Google Threat Intelligence Group, "The Cost of a Call: From Voice Phishing to Data Extortion", 2025.6.4(2025.8 갱신).
[44] 이스트시큐리티 ESRC, 「기능별 C2 서버를 운용하는 Kimsuky 그룹의 새로운 LNK 악성코드 등장」, 2026.9.9.

해킹 침투경로 12 외주 원격접속 계정을 통한 내부망 침입 **국내 발생**



<그림 III-13> 해킹 침투경로 12 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 유지보수 업체 직원의 원격접속 계정이 탈취되면 공격자는 정상 사용자처럼 원청 서버에 접속할 수 있음

□ **(발생 사례)** 북한 해킹조직이 방산 협력업체 서버 유지보수 업체 직원의 계정을 탈취하여 악성코드를 감염시키고, 관리가 소홀한 망연계 시스템을 거쳐 내부망에 침입하여 방산업체 10 여 곳의 자료를 탈취함(2024.4 경찰 발표)[45]

○ 더존비즈온은 직원의 VPN 계정을 통한 무단 접속 피해를 입음(2026.10)[46]

□ **(대응 방향)** 원격접속 2 차 인증·IP 제한, 최소 권한·최소 기간 부여, 접속 기록 상시 점검

[45]경향신문, 「경찰 "북한 해커 조직, 국내 10 여 개 방산업체 기술 탈취"」, 2024.4.23.
[46]뉴스 1, 「토종 1 위 ERP 더존비즈온 해킹… 고객사 민감정보 유출 가능성」, 2026.10.26.

04 민간 기업·SaaS 해킹 침투경로

□ 침투경로 1·2·4·5 는 기업의 이벤트·가입 신청 폼에서도 동일하게 발생하며, 개인정보보호위원회 과태료 의결 8 건 가운데 다수가 민간 기업임[47]

□ 민간에서는 다수 고객사의 자료를 한곳에 보관하는 **SaaS 집중 위험**과 **사람을 속이는 계정·권한 탈취**가 피해를 키움

해킹 침투경로 13 | **SaaS 플랫폼 침해의 고객사 전체 확산** | **국내 발생**



<그림 III-14> 해킹 침투경로 13 발생 구조

자료: 연구진 작성

[47] 이현섭(법무법인 세움), 「구글폼 응답이 다른 응답자에게 보였다면 과태료 대상일까요? — 결정문 8 건의 기준」, 2026.10.19.

□ **(발생 구조)** 다수 기업·기관이 사용하는 SaaS 가 침해되면 고객사별로 분리되지 않은 자료가 일괄 유출되어 피해가 고객사 전체로 확산됨

□ **(발생 사례)** 더존비즈온, 맑은소프트, 자비스 등 국내 SaaS 침해가 연이어 발생함(<참고 III-1>)[48]

□ **(AI 영향)** 탈취한 대량 자료를 AI 가 가치별로 분류하고 협박 금액·문구까지 작성한 사례가 해외에서 확인됨[49]

□ **(대응 방향)** 도입 전 보안인증 여부, 고객사별 데이터 분리, 보관·파기 기준, 사고 통지 의무 확인 및 계약 종료 시 삭제 증빙 확보

참고 III-1 더존비즈온 침해 사고 개요(2026.10~11)

- **(침해 내용)** 직원 VPN 계정을 통한 무단 접속으로 ERP '스마트 A10' 고객사의 성명·주민등록번호·계좌번호 등 유출 가능성이 제기되었고, 백업 서비스 서버 취약점으로 암호화된 데이터가 반출됨[50]
- **(정부 대응)** 과학기술정보통신부는 '중대한 사고'로 판단하여 한국인터넷진흥원과 민관합동조사단을 구성함[51]
- **(영향 범위)** 스마트 A10 은 11 만 개 이상 기업이 이용(회사 측)하며, 임직원 급여 계좌, 연말정산용 가족 주민등록번호, 거래처 정보까지 포함될 수 있음[52]
- **(공공 영향)** 유출 가능성을 공지한 고객사에 국립박물관단지·춘천문화재단 등 공공부문 기관이 포함되었고, 서비스 종료 후에도 데이터가 삭제되지 않은 사례가 확인됨[53]
- **(별도 사고)** 2026 년 7 월 온라인 고객센터의 파일 업로드 취약점을 통한 별도 유출이 확인됨[54]

[48]보안뉴스, 「맑은소프트 개인정보 유출 규모 237 만건… 고객사 22 곳 불똥」, 2026.10.13. ; 보안뉴스, 「 '사칭' 이라던 자비스, 실제 뚫렸다… 공동인증서·결제 정보 등 유출 확인」, 2026.11.6.
[49]Anthropic, "Detecting and countering misuse of AI: August 2025", 2025.8.27.
[50]뉴스 1, 「토종 1 위 ERP 더존비즈온 해킹… 고객사 민감정보 유출 가능성」, 2026.10.26.
[51]보안뉴스, 「[더존비즈온 사태] 급여 계좌부터 가족 주민번호까지… 더존비즈온 해킹이 '중대 사고' 인 이유」, 2026.11.2.
[52]보안뉴스, 「[더존비즈온 사태] 급여 계좌부터 가족 주민번호까지… 더존비즈온 해킹이 '중대 사고' 인 이유」, 2026.11.2.
[53]보안뉴스, 「[더존비즈온 사태] 11 월 5 일 유출 의심 기업 현황… 서울시 육아종합지원센터 유출 가능성」, 2026.11.5.
[54]MTN 머니투데이방송, 「[단독] 더존비즈온, 7 월 고객센터도 뚫렸다…개인정보 8 개 항목 유출」, 2026.11.5.

해킹 침투경로 14 **계정 거래·전화 사칭을 통한 대량 반출** **국내·해외 발생**



<그림 III-15> 해킹 침투경로 14 발생 구조

자료: 연구진 작성

□ **(발생 구조)** 피싱 메일이나 IT 지원팀 사칭 전화로 계정을 탈취하거나 악성 연동 앱 승인을 받아 메일·클라우드·고객관리 자료를 일괄 반출함

□ **(발생 사례)** 국내에서는 네이버 인기 블로그 운영자에게 '해외 로그인' 경고를 사칭한 메일을 보내 약 150개 계정을 해킹하고 개당 1,000 만~1,500 만 원에 판매한 일당이 검거됨(2022)[55]

○ 해외에서는 IT 지원팀 사칭 전화로 연동 앱 승인을 받아 세일즈포스 고객 자료를 반출하고 수개월 뒤 협박한 조직(UNC6040)이 추적됨(2025)[56]

□ **(대응 방향)** 연동 앱 승인 권한의 관리자 한정, IT 지원 요청의 대표번호 역확인, 피싱 저항형 인증 적용

05 소결

□ **(발생 현황)** 14 개 경로 중 핵심 단계가 국내에서 확인된 경로 8 개(침투경로 2 는 계정 침해 단계까지), 해외 1 개, 발생 가능성 높음 5 개임

□ **(구조적 원인)** 직접 운영 경로의 출발점은 응답이 기관이 아닌 개인 계정에 축적되는 구조이며, 외주 경로는 기관이 수탁업체 환경을 확인할 수 없는 구조, 민간 경로는 다수 고객사 자료의 집중 구조에서 비롯됨

□ **(AI 의 역할)** AI 는 각 경로의 탐색·미끼 제작·내부 정찰을 자동화하여, 발생 가능성 높음으로 분류된 침투경로(3·5·6·7·11)의 현실화 시점을 앞당길 수 있음

□ **(우선순위)** 이미 처분·사고가 있는 침투경로(1·2·8·9·10)는 수집 도구 전환과 관리체계 정비로 우선 대응하고, AI 로 확대되는 침투경로(3·5·6·7·11)는 선제적 통제가 필요함

[55]경향신문, 「네이버 인기 블로그 계정 해킹하고 판매한 일당 검거」, 2022.11.16.
[56]Google Threat Intelligence Group, "The Cost of a Call: From Voice Phishing to Data Extortion", 2025.6.4(2025.8 갱신).

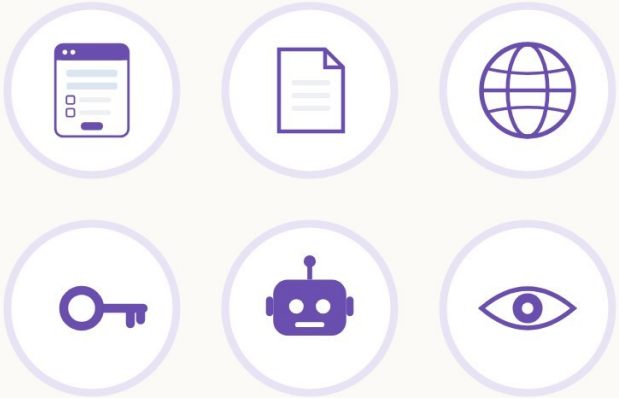
Part 4.

미인증 외부 설문도구의 취약 요인과 우선 점검 대상

Structural Weaknesses

01 미인증 외부 설문도구의 6 대 기술적 취약 요인

02 업무 특성에 따른 외주 업종별 우선 점검 대상



01 미인증 외부 설문도구의 6 대 기술적 취약 요인

□ **(전제)** 구글폼·네이버폼 등 서비스 자체의 보안 수준이 낮다는 의미가 아님. 구글은 모든 폼 하단에 비밀번호 제출 금지 경고를 자동 표시하고 민감 항목 요구 폼을 탐지·차단한다고 밝힘[57]

□ **(핵심)** 취약성은 서비스의 보안 수준이 아니라 **도구가 기관의 보안 통제 범위 밖에 있다는 구조**에서 발생함



<그림 IV-1> 미인증 외부 설문도구의 6 대 취약 요인

자료: 연구진 작성

<표 IV-1> 6 대 취약 요인의 기술적 내용과 근거

요인	기술적 내용	근거
① 불특정 다수 입력	로그인 없이(또는 임의 계정으로) 누구나 입력할 수 있도록 설계됨. 기관 시스템 대부분은 내부 사용자 전용이나 폼은 외부인의 입력을 의도적으로 수신함	구조적 특성
② 외부 파일 유입	업로드 파일이 담당자 저장공간에 축적되어 담당자 PC 에서 열림. 허용 형식을 제한해도 해당 형식 내 악성 기능 은닉이 가능하며, 기관의 백신·격리 검사를 거치지 않음	업무 문서 위장 악성 파일[58], 업로드 기능 취약점에 의한 서버 침해: 모두투어(웹셸, 306 만 건, 과징금 7 억 4,700 만 원)[59], 더존 고객센터[60]
③ 신뢰 도메인 악용	대형 포털 주소와 정상 인증서를 사용하여 보안 장비의 예외 처리 대상이 되기 쉬움. 정상 클라우드 서비스가 공격 명령 통로로 악용되기도 함	사칭 구글폼 265 개[61], 구글 시트·드라이브를 명령 통로로 쓴 도구[62]

[57]Forbes(Davey Winder), "Google Forms Used In Password-Stealing Spree: What You Need To Know"(Zimperium 연구 인용), 2020.11.3.
[58]이스트시큐리티 ESRC, 「기능별 C2 서버를 운용하는 Kimsuky 그룹의 새로운 LNK 악성코드 등장」, 2026.9.9.
[59]경향신문, 「고객정보 306 만건 유출 '모두투어' …과징금 7 억 5000 만원」, 2025.3.13.
[60]MTN 머니투데이방송, 「[단독] 더존비즈온, 7 월 고객센터도 뚫렸다…개인정보 8 개 항목 유출」, 2026.11.5.
[61]Forbes(Davey Winder), "Google Forms Used In Password-Stealing Spree: What You Need To Know"(Zimperium 연구 인용), 2020.11.3.
[62]Google Cloud, "April 2023 Threat Horizons Report".

요인	기술적 내용	근거
④ 계정 단위 결합	폼이 담당자 계정의 메일·드라이브·저장 비밀번호·연결 앱과 결합되어 있어 계정 탈취 시 피해가 계정 전체로 확산됨. 세션 탈취로 2 단계 인증 우회 가능	교육용 구글 계정 11 만 개[63], 세션 되살리기[64], 세션 가로채기 피싱[65]
⑤ AI 입력 전환	AI 비서가 응답 시트를 읽는 순간 응답 내용이 AI 입력이 되며, AI 의 메일·문서 접근 권한만큼 피해 범위가 확대됨	EchoLeak[66], GeminiJack[67]
⑥ 기관 통제 밖	기관 보안관제·접속기록 체계와 미연동. 내려받기 이력 확인 불가, 사고 시 조사 협조 계약 부재, 해외 저장 가능성	국민사서함 이력 확인 불가[68], 국외이전 안내 미흡 66.4%[69]

자료: 연구진 작성

02 업무 특성에 따른 외주 업종별 우선 점검 대상

□ **(평가 방법)** AI 공격은 보유 정보의 가치가 높고 방어 역량이 약한 곳을 우선 표적으로 삼으므로, 국내 외주 업종을 ‘보유 정보의 가치’와 ‘취약성’ 두 축으로 정성 평가함. 업종별 이용 실태·사고율을 비교한 결과가 아니므로 객관적 위험 순위가 아닌 **우선 점검 대상 제안**으로 활용해야 함

○ (가치) 정보의 규모, 민감도(주민등록번호·가족·급여 등), 내부망 접근 여부

○ (취약성) 무료 도구 의존도, 서류 업로드 비중, 자료 보관·파기 관리 수준, 보안 인력

[63]뉴시스, 「6 개 지역서 학교 구글 계정 11 만개 해킹…"비번 360 만개 변경 완료"」, 2026.10.22.
[64]CloudSEK, "Compromising Google Accounts: Malwares Exploiting Undocumented OAuth2 Functionality for session hijacking", 2023.12.29.
[65]Microsoft Threat Intelligence, "From cookie theft to BEC: Attackers use AiTM phishing sites as entry point to further financial fraud", 2022.7.12.
[66]P. Reddy, A. S. Gujral, "EchoLeak: The First Real-World Zero-Click Prompt Injection Exploit in a Production LLM System", arXiv:2509.10540, 2025.9.
[67]Noma Security, "GeminiJack: the Google Gemini zero-click vulnerability leaked Gmail, Calendar and Docs data", 2025.12.8.
[68]경북도민일보, 「천하람 "국민사서함 3 만 8000 건 답변도 없이 폐기"」, 2026.10.29.
[69](재)한국컨설팅산업재단 부설 개인정보보호진흥원·국회 박상혁 의원실, 「공공기관 온라인설문 개인정보 수집실태」 보도자료 및 붙임 조사결과(조사기간 2026.8.21.~10.5.).



<그림 IV-2> 업무 특성에 따른 외주 업종별 우선 점검 대상

자료: 연구진 작성(공개 사례와 업무 특성에 근거한 정성 평가)

<표 IV-2> 외주 업종별 위험 요인과 국내 사례

업종	보유 정보	취약 요인	국내 사례	점검 순위
채용 대행·인력 아웃소싱	주민등록번호, 학력·경력, 사진, 가족관계 서류	서류 업로드 다수, 근거 없는 주민번호 수집	인사서류 5 만 건 유출[70], 지자체 채용 외주 페이지 노출[71]	1
세무·회계 ERP(SaaS)	임직원·가족 주민번호, 급여 계좌, 거래처	다수 고객 자료 집중	더존비즈온[72], 자비스[73]	1
IT 유지보수·보안 용역	내부망 접근 권한	원격접속 계정, 외부 도구 사용	방산 협력업체[74], 1 호기 명단[75]	1
리서치·여론조사	대규모 국민 응답, 연락처, 성향	무료 도구·웹하드 의존	15 곳 중 14 곳 법 위반(2018 점검)[76], 북한의 공격 시도[77]	1
교육·연수 위탁	공직자 명단(성명·소속·직급·연락처)	옛 서버 방치, 자체 점검 의존	공직자 10 만여 명 유출[78]	1
홈페이지 제작·운영	신청자 정보	취약점 관리 미흡	지자체 산하 홈페이지 노출 위험[79]	2

[70]미디어오늘, 「직원 가족·입사 지원자 개인정보 '탈탈' 털린 콜센터 업체」, 2026.4.23.
[71]보안뉴스, 「거제시 이어 경기도 산하 홈피까지 개인정보 노출 위험 드러나... 지자체 보안 부실은 외주 탓?」, 2024.6.21.
[72]뉴스 1, 「토종 1 위 ERP 더존비즈온 해킹… 고객사 민감정보 유출 가능성」, 2026.10.26.
[73]보안뉴스, 「 '사칭' 이라던 자비스, 실제 뚫렸다... 공동인증서·결제 정보 등 유출 확인」, 2026.11.6.
[74]경향신문, 「경찰 "북한 해커 조직, 국내 10 여 개 방산업체 기술 탈취"」, 2024.4.23.
[75]MBC, 「[단독] "1 호기 명단', 보안 업체서 고유 식별값 대신 원본 파일 올려"」, 2026.11.5.
[76]KBS, 「[단독] "여론조사업체 15 곳 중 14 곳 법 위반" 개인 정보 '구멍' …실태도 '깜깜' 」, 2025.4.25.
[77]SBS, 「[단독] 북, 총선 전 여론조사 기관 공격…선거 혼란 노렸나」, 2024.5.24.
[78]경향신문, 「[단독]10 만명 공직자 정보 유출…"파기 완료" 위탁업체 1 년 반 허위 보고, 권익위는 몰랐다」, 2026.10.21.
[79]보안뉴스, 「거제시 이어 경기도 산하 홈피까지 개인정보 노출 위험 드러나... 지자체 보안 부실은 외주 탓?」, 2024.6.21.

업종	보유 정보	취약 요인	국내 사례	점검 순위
행사·이벤트 대행	성명·연락처·주소, 경품용 주민번호	단기 사업, 무료 폼 의존	방청객 모집 폼 2,716 명 노출 등[80]	2
마케팅·홍보 대행	대량 연락처, 소비 성향	무료 폼 의존, 재위탁	공개 사례 미확인	2
경영·조직 컨설팅	임직원 설문·인터뷰, 내부 자료	개인 계정 공유 드라이브	공개 사례 미확인	3

자료: 연구진 작성

□ **(시사점)** 1 순위 업종에 업무를 위탁하는 기관·기업은 계약 시 보안인증 도구 사용과 파기 확인을 우선 반영할 필요가 있음(VI 장 3 절)

[80] 이현섭(법무법인 세움), 「구글폼 응답이 다른 응답자에게 보였다면 과태료 대상일까요? — 결정문 8 건의 기준」, 2026.10.19.

Part 5.

대응 방안: 클라우드 보안인증 체계의 활용

Certified Cloud as the Answer

01 클라우드 보안인증 제도 개요

02 제도 연혁

03 보안인증 도구는 어떻게 해킹을 막는가

04 미인증 도구 대비 통제 수준 비교

05 적용 원칙: 공공 의무, 민간 적극 도입

06 한계 및 보완



01 클라우드 보안인증 제도 개요

□ **(개념)** 공공기관이 이용할 민간 클라우드 서비스의 보안 수준을 국가가 사전에 평가하여, 국민 정보를 맡겨도 되는지를 확인하는 제도임

□ **(목적)** 공공기관의 민간 클라우드 활용을 확대하는 동시에, 국민 정보가 국내에·기관 통제 아래 보관되고 사고 시 국가가 조사할 수 있도록 보장함

□ **(운영 체계)** 클라우드 보안인증(CSAP)은 과학기술정보통신부와 한국인터넷진흥원이 운영하며, 국가정보원은 공공기관이 이용할 수 있는 서비스를 「국가·공공기관 민간 클라우드 컴퓨팅서비스 도입 가능 목록」으로 공개함(2026.9.30. 기준 219 건)[81]

- ○ 인증은 관리적·물리적·기술적 보호조치와 공공기관용 추가 보호조치 등 서비스 유형·등급에 따라 30~117 개 통제항목을 점검하며, 인증 후 매년 사후 평가를 실시함[82]
- ○ 「국가 사이버보안 기본지침」은 민간 클라우드 이용 시 목록 등재 서비스를 이용하고, 계약에 보안관제·사고조사 협조를 명시하도록 규정함[83]

<표 Ⅴ-1> 공공기관용 추가 보호조치의 주요 항목

항목	내용
도입 전산장비 안전성	CC 인증 제품 또는 국가정보원장이 안전성을 확인한 제품 사용
물리적 위치 및 분리	클라우드 시스템·데이터, 백업 시스템, 관리·운영 인력의 물리적 위치를 국내로 한정하고 공공기관용 영역을 분리
검증필 암호화	중요자료 암호화 시 검증된 암호 기술 사용
보안관제 지원	국가기관 등의 보안관제를 위한 환경 지원
데이터 유출 방지	데이터의 무단 국외 유출 방지

자료: 김·장 법률사무소(2023)[84], 윤대균(2024)[85] 재구성

[81]국가정보원, 「국가·공공기관 민간클라우드 컴퓨팅서비스 도입 가능목록」(2026.9.30. 기준).
[82]국가법령정보센터, 「클라우드컴퓨팅서비스 보안인증에 관한 고시」(과학기술정보통신부고시 제 2023-4 호, 2023.1.31.). ; 윤대균(아주대학교), 「CSAP 및 FedRAMP 최근 동향」, 디지털서비스 이슈리포트 2024-07, 조달청, 2024.7.31.
[83]국가정보원, 「국가 사이버보안 기본지침」(2026.5.1.) 제 2 조, 제 24 조의 3·제 24 조의 4.
[84]김·장 법률사무소, 「 '클라우드컴퓨팅서비스 보안인증에 관한 고시' 개정안 시행」, 2023.
[85]윤대균(아주대학교), 「CSAP 및 FedRAMP 최근 동향」, 디지털서비스 이슈리포트 2024-07, 조달청, 2024.7.31.

02 제도 연혁



<그림 Ⅴ-1> 클라우드 보안인증 제도 연혁

자료: 디지털투데이(2023.8.11.), 뉴스 1(2026.9.22.) 재구성

□ **(도입과 확산)** 2016 년 첫 인증 이후 2019 년 SaaS 간편등급, 2023 년 상·중·하 등급제가 도입되었고, 국가정보원은 2023 년 도입 가능 목록을 공개함(2023 년 7 월 말 기준 89 개)[86]

□ **(개편 방향)** 정부는 2026 년 4 월 공공 클라우드 보안정책 개편 방안을 발표하였고, 국가정보원은 9 월 기밀·민감·공개 등급별 클라우드 이용 조건을 공개함[87]

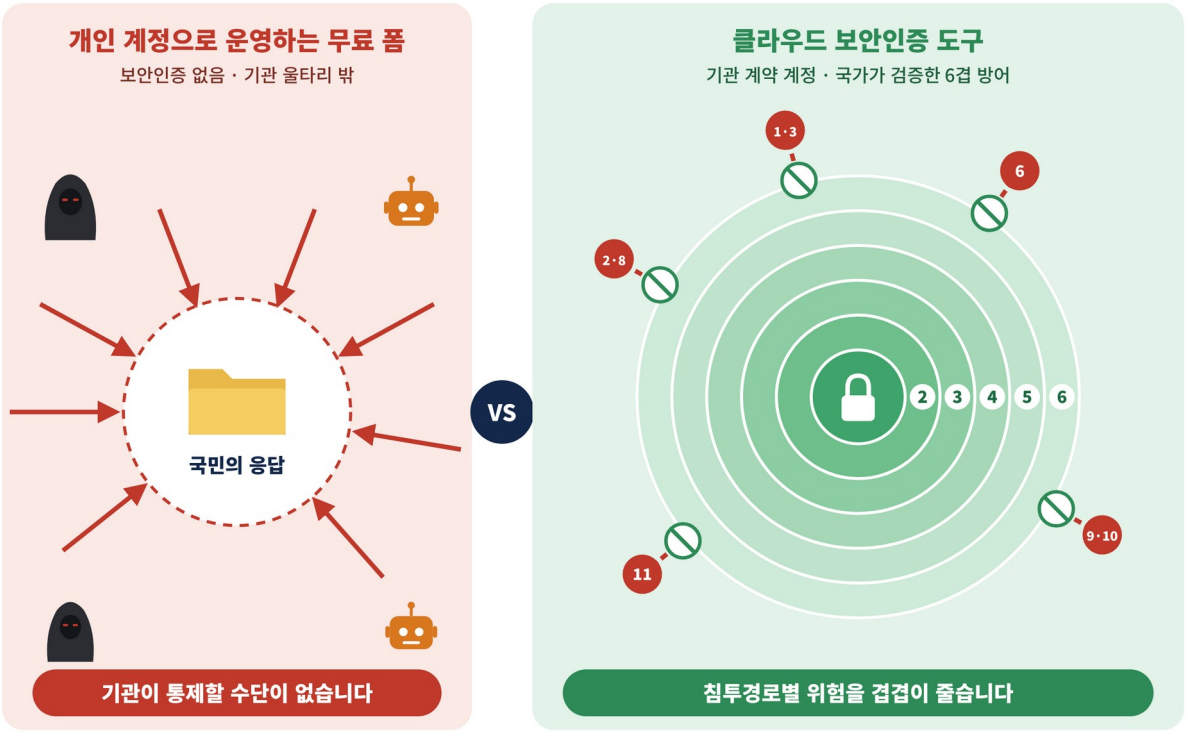
○ 2027 년 하반기부터 인증과 보안검증으로 이원화된 절차를 국가정보원 보안검증으로 일원화할 예정임

○ 명칭과 절차가 변경되더라도 **'국가가 검증한 클라우드 서비스를 이용한다' 는 원칙**은 유지됨

[86]디지털투데이, 「국정원, 국가·공공기관 도입 가능 클라우드 서비스 89 개 공개」, 2023.8.11.
[87]뉴스 1, 「국정원, 공공 클라우드 보안체계 구체화…등급별 이용조건 공개」, 2026.9.22.

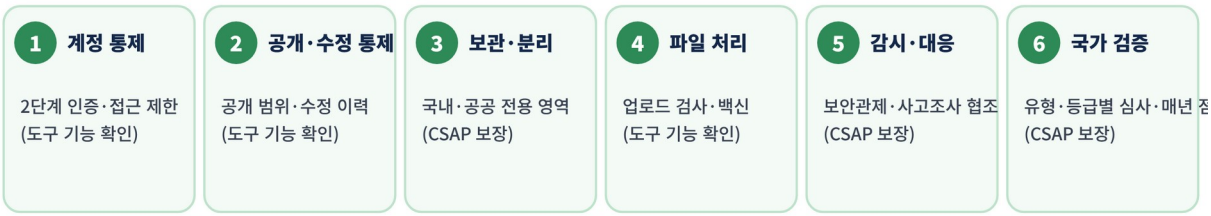
03 보안인증 도구는 어떻게 해킹을 막는가

□ **(전체 구조)** 보안인증 도구는 국민의 응답을 **여섯 겹의 방어 장치**로 둘러싸, 미인증 무료 폼에서 그대로 통과하던 공격을 단계마다 줄이거나 차단함



<그림 Ⅴ-2> 미인증 무료 폼과 보안인증 도구의 방어 구조 비교

자료: 연구진 작성



<그림 Ⅴ-3> 보안인증 도구의 6겹 방어 장치

자료: 연구진 작성

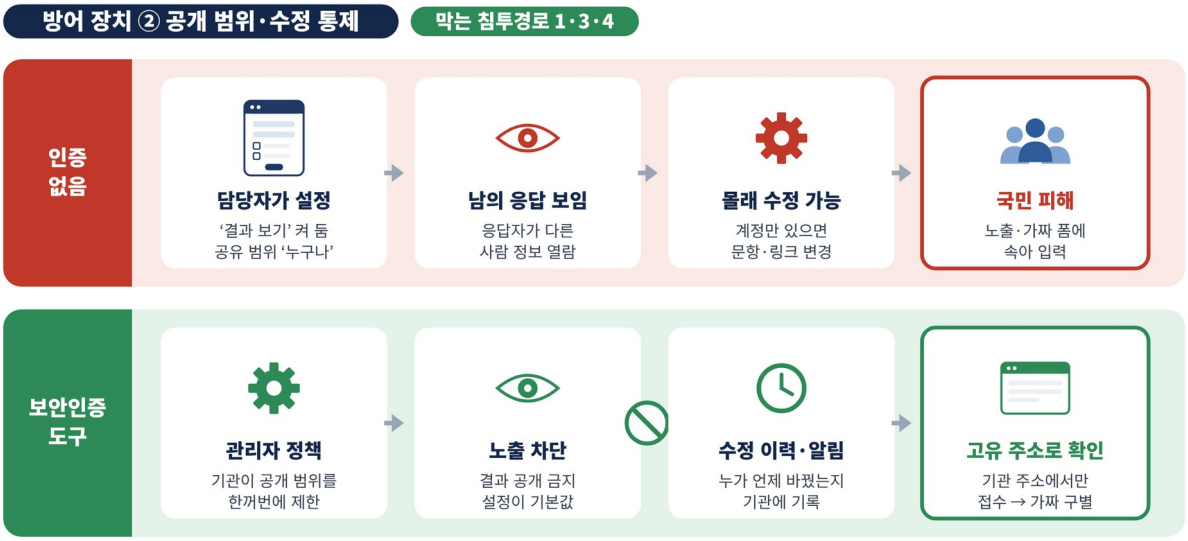
□ **(작동 방식)** 각 방어 장치가 어떤 해킹 침투경로를 어느 단계에서 끊는지를 같은 공격 상황으로 비교하면 다음과 같음



<그림 Ⅴ-4> 방어 장치 ① 계정 통제: 비밀번호가 새도 접근을 어렵게 함

자료: 연구진 작성

○ 기관이 계정을 소유하므로 2 단계 인증·접속 IP 제한을 일괄 적용하고, 이상 접속 시 즉시 권한을 회수할 수 있음(침투경로 2·3·8·14)



<그림 Ⅴ-5> 방어 장치 ② 공개 범위·수정 통제: 설정 실수와 바꿔치기 차단

자료: 연구진 작성

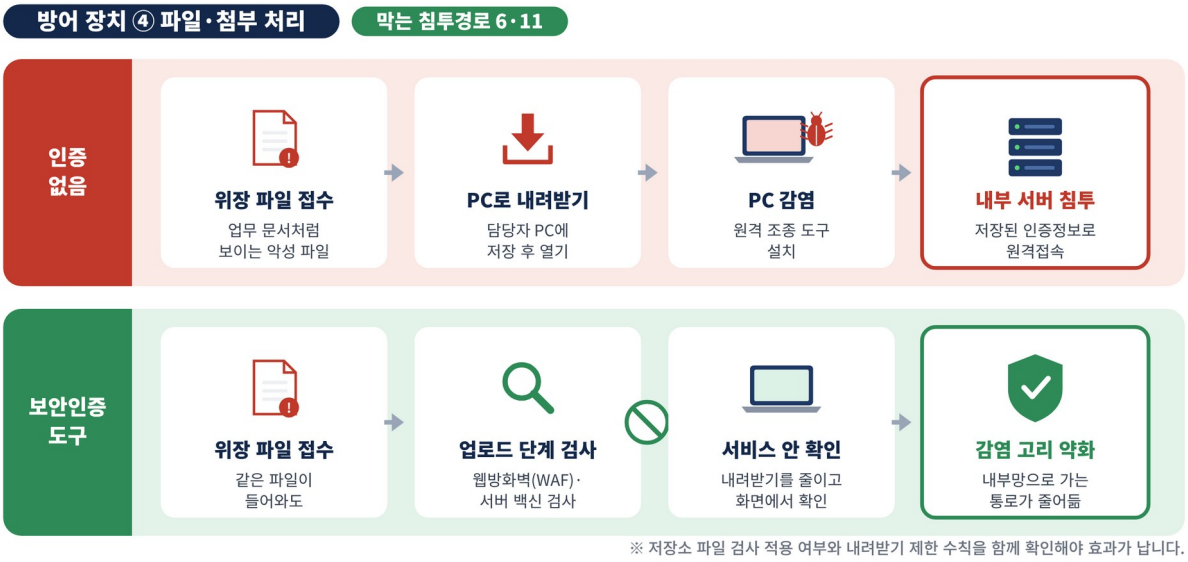
○ 공개 범위를 관리자 정책으로 제한하고 수정 이력을 기록하여, 설정 실수와 공식 폼 변조를 막고 진위 확인을 쉽게 함(침투경로 1·3·4)



<그림 Ⅴ-6> 방어 장치 ③ 자료 보관·분리: 국내 공공 전용 영역에 보관

자료: 연구진 작성

○ 자료를 인증된 서비스 안에만 두고 국내에 보관하며, 사업 종료 시 일괄 파기하여 외주업체·개인에게 사본이 남지 않게 함(침투경로 7·9·10)



<그림 Ⅴ-7> 방어 장치 ④ 파일·첨부 처리: PC 감염 고리를 약화

자료: 연구진 작성

○ 업로드 단계에서 웹방화벽(WAF)·서버 백신으로 검사하고 서비스 안에서 확인하게 하여, 담당자 PC 를 거쳐 내부망으로 이어지는 고리를 약화시킴(침투경로 6·11). 저장소 파일 검사 적용 여부와 내려받기 제한 수칙을 함께 확인해야 함



<그림 Ⅴ-8> 방어 장치 ⑤ 감시·사고 대응: 조용한 침입을 드러냄

자료: 연구진 작성

○ 보안관제 지원과 계약상 사고조사 협조로 정상 사용자로 위장한 침입을 조기에 발견하고 국가가 조사할 수 있게 함(침투경로 6·13)



<그림 Ⅴ-9> 방어 장치 ⑥ 국가 검증 절차

자료: 연구진 작성

○ 인증 기준에 해당하는 보호조치(③ 보관·분리, ⑤ 감시·대응 등)를 국가가 사전에 심사하고 매년 다시 점검함. 제품별 세부 기능(① 계정, ② 공개·수정, ④ 파일)은 이용기관이 도입 시 확인해야 함

□ **(종합)** 도입 시 확인 항목(<표 Ⅴ-3>)을 갖춘 보안인증 도구를 기준으로 14 개 해킹 침투경로별 방어 장치의 적용 관계와 해킹 방어효과를 판단함

○ 방어 장치 중 ③ 보관·분리와 ⑤ 감시·대응은 인증 기준으로 보장되는 항목이며, ① 계정 통제·② 공개·수정 통제·④ 파일 처리는 제품별로 갖춰야 하는 기능이므로 도입 시 확인이 필요함

	① 계정 통제 (도구 기능)	② 공개·수정 통제 (도구 기능)	③ 보관·분리 (CSAP 보장)	④ 파일 처리 (도구 기능)	⑤ 감시·대응 (CSAP 보장)	해킹 방어효과 (확인 항목을 갖춘 인증 도구)
1 설정 실수로 응답 노출	·	●	·	·	·	크게 줄어듦
2 폼 주인 계정 탈취	○	·	·	·	○	크게 줄어듦
3 공식 폼 바꿔치기	○	◌	·	·	○	크게 줄어듦
4 기관 사칭 가짜 폼	·	○	·	·	·	일부 줄어듦
5 숨은 명령으로 AI 비서 조종	·	·	·	·	·	별도 대책
6 첨부파일 → 내부 서버	·	·	·	○	○	크게 줄어듦
7 유출 명단 → AI 피싱	○	·	○	·	·	크게 줄어듦
8 외주업체 계정 탈취	○	◌	○	·	○	크게 줄어듦
9 끝난 사업 자료 잔존	·	◌	◌	·	·	크게 줄어듦
10 외부 사이트 업로드	·	◌	○	·	·	해킹경로 차단
11 납품 파일·연동 앱	·	◌	·	○	·	해킹경로 차단
12 외주 원격접속 → 내부망	·	·	·	·	·	도구 범위 밖
13 인증 SaaS 플랫폼 자체 침해	◌	·	○	·	○	크게 줄어듦
14 계정 거래·전화 사칭	○	·	·	·	○	일부 줄어듦

● 직접 막음 ○ 피해를 줄임 ◌ 도입 시 기능 확인 필요

연구진 판단 · ‘CSAP 보장’은 인증 기준 항목, ‘도구 기능’은 제품별 확인 항목

<그림 Ⅴ-10> 해킹 침투경로별 방어 장치와 해킹 방어효과

자료: 연구진 판단(통제수단과 위협의 연결에 근거한 정성 판단으로, 기능 시험 결과가 아님)

○ 14 개 중 12 개 침투경로에 대응하는 통제수단이 있으며, 크게 감소 8 개(1·2·3·6·7·8·9·13), 해킹경로 차단 2 개(10·11), 일부 감소 2 개(4·14)로 판단됨. 실제 효과는 제품의 기능과 기관의 운영 조건에 따라 달라짐

※ ‘해킹경로 차단’ 은 외주업체가 자료를 내려받아 전달하는 업무상 반출 경로가 없어진다는 뜻이며, 화면 캡처 등 의도적 유출은 별도 관리가 필요함

○ 침투경로 5(AI 비서 조종)는 기관의 AI 활용 규칙이, 침투경로 12(외주 원격접속)는 기관 원격접속 관리가 필요한 영역으로 설문 도구의 범위 밖임

04 미인증 도구 대비 통제 수준 비교

□ **(비교 관점)** 비교 대상은 실태조사에서 확인된 **'담당자 개인 계정으로 운영하는 무료 폼'** 이며, 조직용 서비스의 관리·보안 기능을 부정하는 것이 아님. 인증 도구가 기술적으로 반드시 우월하다는 의미도 아니며, 차이는 **공공 도입 요건 충족 여부, 계정 소유, 자료 위치, 사고 시 기관이 확인·요구할 수 있는 범위**에 있음

○ 네이버도 공공기관용 업무 서비스는 별도 제품으로 인증을 받아 목록에 등재되어 있음[88]

	보안인증 없는 무료 폼 담당자 개인 계정	클라우드 보안인증 도구 기관이 계약한 계정
계정 주인	✗ 담당자 개인 이동·퇴직 뒤 회수 어려움	✓ 기관 담당자가 바뀌면 기관이 회수
자료가 있는 곳	✗ 해외 저장 가능	✓ 시스템·데이터·백업·운영 인력 모두 국내
누가 점검하나	✗ 사업자 자체 기준	✓ 국가 인증 심사 + 매년 사후 점검
공공·민간 분리	✗ 일반 이용자와 같은 환경	✓ 공공기관용 영역 분리
기록·감시	✗ 기관이 볼 수 없음	✓ 보안관제 지원
사고가 나면	✗ 조사 협조 약속 없음	✓ 계약에 사고조사 협조 명시
파기 확인	✗ 담당자 개인 판단	✓ 계약으로 파기 확인

<그림 Ⅴ-11> 미인증 무료 폼과 보안인증 도구의 통제 수준 비교

자료: 연구진 작성

<표 Ⅴ-2> 보안인증 도구 전환 시 침투경로별 해킹 방어효과

해킹 방어효과	해당 침투경로	근거 및 전제 조건
크게 감소	1 · 2 · 3 · 6 · 7 · 8 · 9 · 13	결과 비공개 기본값, 전 계정 2 단계 인증, 수정 이력·알림, 업로드·저장소 파일 검사, 외주 계정·권한 관리, 파기 증빙, 플랫폼 권한 통제를 갖춘 경우
해킹경로 차단	10 · 11	외주업체 내려받기 제한과 서비스 내 결과 확인으로 업무상 반출 경로가 없어짐(의도적 유출은 별도 관리)
일부 감소	4 · 14	사칭·사람을 속이는 공격은 도구 밖 요인이 남음. 보안키·패스키 도입 시 추가 감소
별도 대책	5	기관의 AI 비서 활용 규칙 필요
도구 범위 밖	12	기관 원격접속(VPN) 관리 영역

자료: 연구진 판단

[88] 국가정보원, 「국가·공공기관 민간클라우드 컴퓨팅서비스 도입 가능목록」(2026.9.30. 기준).

05 적용 원칙: 공공 의무, 민간 적극 도입

□ **(공공기관: 의무 이행 강화)** 지침상 의무가 존재함에도 개인정보 수집 설문 149 건이 미인증 도구로 운영되는 등 일선 이행이 미흡하므로 이행 점검 강화가 필요함[89]

□ **(민간 기업: 적극 도입 권장)** 법적 의무는 없으나 고객·임직원 개인정보를 수집하는 폼과 SaaS 는 인증 도구를 우선 검토할 필요가 있음

- ○ 사고 시 과징금 부담이 큼: 모두투어 7 억 4,700 만 원[90], KS 한국고용정보 35 억 3,700 만 원[91]
- ○ 도입 가능 목록은 공공기관용이나, 민간 기업이 서비스 선정 시 '국가가 점검한 서비스' 목록으로 활용 가능함

□ **(교육현장 예외의 재검토)** 「국가 사이버보안 기본지침」은 국·공립학교 등의 교육 목적 정보통신환경을 '교육현장'으로 정의하고, 교육현장에는 도입 가능 목록 서비스 이용 의무(제 24 조의 4 제 1 항)를 적용하지 않고 학교장 책임에 맡기고 있음[92]. 교육부 지침도 교육현장은 학교장 책임 하에 민간 클라우드를 이용할 수 있도록 규정함[93]

- ○ 그러나 2026 년 10 월 대규모 계정 침해(교육용 구글 계정 11 만 2,890 개)는 바로 이 예외 영역에서 발생하였으며, 졸업생·퇴직자 계정 정리 규정조차 없었음[94]
- ○ 예외의 필요성(수업 활용의 유연성)은 인정하더라도, 예외 영역에 2 단계 인증·장기 미사용 계정 정리·접속 기록 확인 등 **최소 계정 보안 기준**을 의무화하고, 학생·교직원 개인정보를 수집하는 업무에는 예외를 적용하지 않는 방안을 검토할 필요가 있음

06 한계 및 보완

□ **(인증 보장과 도구 기능의 구분)** 인증은 국내 보관, 공공 전용 영역 분리, 보안관제 지원, 사고조사 협조, 매년 점검 등을 보장하나, 2 단계 인증·접근 제한·공개 범위 통제·파일 검사·감사 기록·외주 계정 관리·파기 증빙은 제품별로 구현 수준이 다르므로 도입 전 확인이 필요함

<표 Ⅴ-3> 보안인증 설문 도구 도입 전 확인 항목

구분	확인 항목	관련 침투경로
계정	전 계정 2 단계 인증, 로그인 실패 잠금, 접속 IP 제한, 공공기관 인증 연계	2 · 3 · 8 · 14
공개·수정	결과 공개 기본 비공개, 설문별 소유자 검사, 수정 이력·알림	1 · 3 · 4
파일	업로드 검사(WAF), 저장소 파일 백신 검사, 서비스 내 열람	6 · 11
외주·권한	조직·역할별 권한, 외주 계정 발급·회수, 내려받기 제한	8 · 9 · 10 · 11
기록·파기	조회·내려받기 감사 기록, 종료 시 일괄 파기와 증빙	7 · 9 · 13

[89](재)한국컨설팅산업재단 부설 개인정보보호진흥원·국회 박상혁 의원실, 「공공기관 온라인설문 개인정보 수집실태」 보도자료 및 붙임 조사결과(조사기간 2026.8.21.~10.5.).
[90]경향신문, 「고객정보 306 만건 유출 '모두투어' …과징금 7 억 5000 만원」, 2025.3.13.
[91]미디어오늘, 「직원 가족·입사 지원자 개인정보 '탈탈' 털린 콜센터 업체」, 2026.4.23.
[92]국가정보원, 「국가 사이버보안 기본지침」(2026.5.1.) 제 2 조, 제 24 조의 3·제 24 조의 4.
[93]교육부, 「교육부 정보보안 기본지침」(2023.11.21.) 제 41 조제 7 항.
[94]뉴시스, 「6 개 지역서 학교 구글 계정 11 만개 해킹…"비번 360 만개 변경 완료"」, 2026.10.22. ; 뉴시스, 「대전 학교 구글 비번 7 만개 '무단 변경' … 졸업생·퇴직자도 피해 가능성」, 2026.10.13.

구분	확인 항목	관련 침투경로
플랫폼	고객사별 데이터 분리, 서버 운영 환경 권한·네트워크 통제, 사고 통지 의무	13

자료: 연구진 작성

□ **(평가 대상의 한계)** 인증은 서비스 제공자의 보호조치를 평가하므로, 이용기관의 설정 오류·계정 관리·피싱 대응은 별도 운영 수칙으로 보완해야 함

□ **(AI 기능)** AI 요약·분석 기능을 탑재한 서비스는 간접 프롬프트 인젝션 대응 여부를 별도로 확인해야 함[95]

□ **(집중 위험)** 다수 고객사 공용 서비스는 인증 여부와 무관하게 고객사별 데이터 분리와 파기 기준을 계약 단계에서 확인해야 함

□ **(중립성)** 인증과 목록 등재는 특정 제품에 대한 정부 추천이 아니므로, 업무 특성에 맞는 서비스를 목록 내에서 비교·선택해야 함

[95] Google, "Google Workspace's continuous approach to mitigating indirect prompt injections", 2026.4.2.

Part 6.

정책 제언

Policy Recommendations

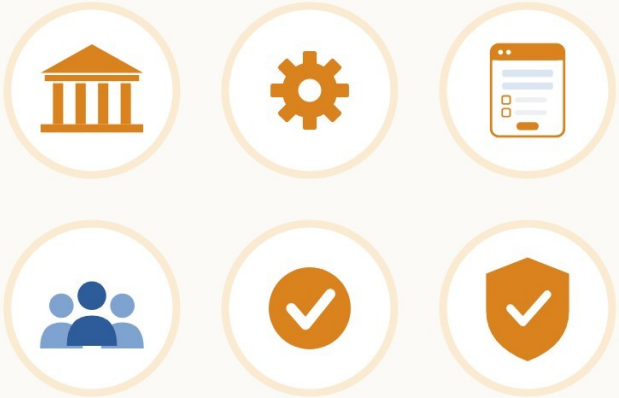
01 도입 대안 비교

02 단계별 추진 로드맵

03 외주 계약 기준 개선

04 제도 개선 과제

05 대국민 안내 강화



01 도입 대안 비교

□ **(대안)** 수집 도구 전환 방식은 보안인증 클라우드 도구 이용(A), 자체 시스템 구축(B), 상위기관 공동 계약(C)의 세 가지로 구분됨



<그림 VI-1> 수집 도구 전환 대안 비교

자료: 연구진 작성

□ **(권고)** 대부분의 기관·기업에는 **A 안이 가장 신속하고 현실적인 대안**이며, 상위기관이 일괄 계약하여 산하기관·학교에 제공하는 C 안이 비용과 운영 부담을 가장 크게 줄임

○ B 안은 통제력이 가장 높으나 보안을 직접 책임져야 하며, 모두투어와 더존 고객센터 사고는 모두 자체 웹사이트의 파일 업로드 기능에서 시작됨[96]

[96]경향신문, 「고객정보 306 만건 유출 '모두투어' …과징금 7 억 5000 만원」, 2025.3.13. ; MTN 머니투데이방송, 「[단독] 더존비즈온, 7 월 고객센터도 뚫렸다…개인정보 8 개 항목 유출」, 2026.11.5.

02 단계별 추진 로드맵

□ **(원칙)** 기술 전환만으로는 한계가 있으므로 기술, 인력·조직, 업무 프로세스를 함께 개선함

<표 VI-1> 단계별 추진 로드맵

구분	기술	인력·조직	업무 프로세스
단기 (즉시~3 개월)	· 개인정보 수집 폼 전수 점검(도구·계정·공개 설정·항목) · 주민번호·건강정보 수집 폼 즉시 중단 · 운영 계정 2 단계 인증 · 보유기간 경과 자료 파기	· 수집 도구 책임자 지정(개인정보 보호책임자 산하) · 담당자 대상 폼 보안 교육	· 폼 게시 전 점검표 의무화 · 진행 중 외주 사업의 수집 도구·계정 확인
중기 (3 개월~1 년)	· 보안인증 도구 전환(A·C 안) · 기관 계정·관리자 통제, 수정 이력 관리 · 수신 파일 격리 열람 환경 · 보안키·패스키 도입	· 부서별 수집 담당자 지정 및 권한 관리 · 인사이동 시 계정 이관 절차 · 외주 관리 담당자 지정	· 과업지시서에 보안인증 도구 사용 조건 반영 · 파기 증빙·현장 확인 절차 · AI 비서 활용 시 외부 응답 분석 규칙
장기 (1~3 년)	· 상시 대규모 수집은 자체 구축·공동 플랫폼 검토(B·C 안) · 원격접속·업무 PC 이상 징후 상시 감시 · AI 기능 도구의 프롬프트 인젝션 대응 확인	· AI 보안 교육 정례화 · 외주업체 보안 평가 체계	· 실태평가·보호수준 평가에 수집 도구 항목 반영 · 가짜 폼·피싱 모의훈련 정례화

자료: 연구진 작성

03 외주 계약 기준 개선

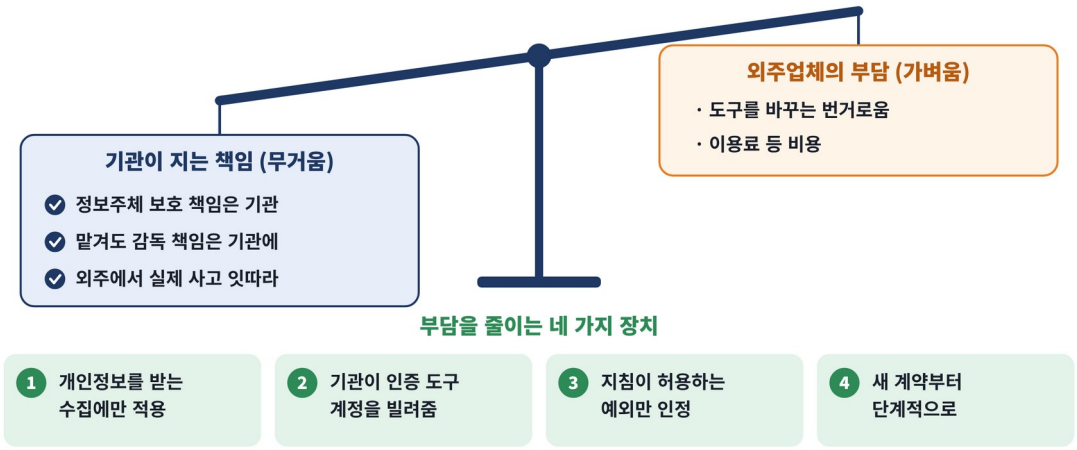
□ **(쟁점)** 외주업체에도 보안인증 도구 사용을 요구하는 것이 과도한 강제인지에 대한 검토가 필요함

□ **(판단)** 법령으로 일률 강제하기보다 **계약 조건으로 요구하는 것이 합리적이며, 과도한 부담으로 보기 어려움**

○ 정보주체의 권리를 보호할 책임은 기관에 있으며, 개인정보보호법 제 26 조에 따라 위탁 후에도 위탁자의 관리·감독 책임이 유지됨. 개인정보보호위원회도 외부 도구 이용 시 안전조치 책임이 이용기관에 있다고 안내함[97]

○ 외주 단계에서 실제 사고가 연이어 발생함(침투경로 8~10)

○ 보안서약서, 개인정보 처리 위탁 계약 등 보안 조건의 계약 반영은 이미 일반화된 관행임



<그림 VI-2> 외주 계약 조건의 적정성 판단

자료: 연구진 작성

□ **(부담 완화 장치)** ① 개인정보 수집에 한정 적용 ② 기관 보유 인증 도구 계정을 수탁업체에 제공 ③ 관계 지침이 허용하는 대체 절차·예외 요건을 충족한 경우에 한해 업체 도구 인정 ④ 신규 계약부터 단계 적용

<표 VI-2> 과업지시서·계약서 반영 문구(예시)

항목	문구 예시
수집 도구	개인정보를 수집하는 경우 클라우드 보안인증을 받은 도구(국가정보원 도입 가능 목록 등재 서비스)를 사용한다. 다만 관계 지침이 허용하는 대체 절차나 예외 요건을 충족한 경우에 한하여 발주기관의 승인을 받아 다른 도구를 사용할 수 있다.
계정	발주기관이 제공하거나 승인한 계정으로 수집하며, 계약 종료 시 즉시 권한을 회수한다.
파기	종료 후 ○일 이내 파기하고 파기 증빙을 제출하며, 발주기관은 현장 확인을 할 수 있다.
외부 업로드 금지	검사·변환·공유 목적이라도 원본을 외부 웹서비스에 업로드하지 않는다.
사고 협조	사고 발생 시 즉시 통지하고 발주기관 및 관계기관의 조사에 협조한다.

자료: 연구진 작성

[97] 개인정보보호위원회, 「외부 설문도구 이용 시 개인정보 처리 준수 사항에 대해 보다 명확히 안내하겠습니다」 보도참고자료, 2026.10.16.

04 제도 개선 과제

- **(교육현장 예외 보완)** 교육현장 예외를 유지하더라도 2 단계 인증, 졸업·퇴직자 계정 정리, 접속 기록 확인 등 최소 계정 보안 기준을 의무화하고, 학생·교직원 개인정보 수집 업무에는 예외를 적용하지 않는 방안 검토
- **(평가 연계)** 국가정보원 사이버보안 실태평가와 개인정보보호위원회 개인정보 보호수준 평가에 '설문·신청 수집 도구 및 외주업체 도구의 인증 여부'를 구체적 점검 항목으로 반영
- **(안내서 보완)** 개인정보보호위원회 외부 설문도구 안내에 보안인증 도구와의 관계를 명확히 하고, 개인 계정 운영 금지를 명시
- **(공동 활용 모델)** 부처·광역자치단체가 인증 도구를 일괄 계약하여 산하기관·학교에 제공하는 공동 활용 모델 지원
- **(AI 기능 평가)** AI 요약·분석 기능을 탑재한 공공용 서비스에 대해 간접 프롬프트 인젝션 대응을 확인하는 평가 기준 마련
- **(위탁 감독 구체화)** 발주기관이 수탁업체의 수집 도구와 계정을 확인하는 절차를 위탁 관리·감독 기준에 구체화

05 대국민 안내 강화

□ **(필요성)** 기관의 도구 전환에는 시간이 소요되므로, 그 기간 동안 국민이 스스로 실천할 수 있는 행동 수칙의 보급이 필요함



<그림 VI-3> 대국민 행동 수칙 10 가지

자료: 연구진 작성

<표 VI-3> 국민 상담·신고 창구

상황	기관(서비스)	연락처
아이디·이메일 유출 여부 확인	털린 내 정보 찾기(개인정보보호위원회·한국인터넷진흥원)	kidc.eprivacy.go.kr
개인정보 노출·유출 신고	개인정보침해 신고센터(한국인터넷진흥원)	118, privacy.kisa.or.kr
사칭 폼·피싱·해킹 피해 신고	경찰청 사이버범죄 신고시스템	ecrm.police.go.kr, 긴급 112
신분증 노출로 인한 금융 명의도용 예방	개인정보노출자 사고예방시스템(금융감독원)	pd.fss.or.kr
명의도용 휴대폰 개통 확인·차단	엠세이퍼 명의도용방지서비스	msafer.or.kr

자료: 각 기관 누리집

Part 7.
결 론

Conclusion

01 요약 및 시사점

02 향후 과제



01 요약 및 시사점

- 설문·신청 양식은 행정과 기업 활동에서 가장 흔한 대국민 접점이자, 불특정 외부인의 입력과 파일을 의도적으로 수신하는 **가장 넓게 열린 진입점**임
- 14 개 해킹 침투경로 중 9 개는 핵심 단계가 이미 국내외에서 확인되었으며, 지금까지의 사고는 대부분 설정 오류, 잔존 자료, 탈취 계정 등 **기관이 통제하지 못한 영역**에서 발생함
- AI 는 이러한 틈을 더 빠르고 넓게 탐색하는 수단으로 작용하고 있으며, 발생 가능성 높음으로 분류된 5 개 경로의 현실화 시점을 앞당길 수 있음
- 확인 항목을 갖춘 보안인증 도구는 14 개 중 12 개 침투경로에 대응하는 통제수단을 제공하며, 이 가운데 10 개는 크게 줄이거나 업무상 반출 경로를 차단할 수 있는 것으로 판단됨(연구진 판단)

02 향후 과제

- **(전환)** 국민 정보를 수집하는 폼을 국가가 검증한 클라우드 도구로 전환하고, 공공기관의 의무 이행 점검을 강화함
- **(확산)** 외주 계약에 보안인증 도구 사용과 파기 확인을 반영하고, 민간 기업의 자발적 도입을 유도함
- **(대비)** AI 비서·AI 내장 악성코드 등 신규 위협에 대한 평가 기준과 운영 수칙을 마련하고, 대국민 행동 수칙을 보급함
- 사고가 공개된 이후의 대응은 이미 늦으며, **수집 단계에서의 선제적 예방**이 가장 비용 효율적인 대응임

참고문헌

1. 국내 문헌

(재)한국컨설팅산업재단 부설 개인정보보호진흥원·국회 박상혁 의원실, 「공공기관 온라인설문 개인정보 수집실태」 보도자료 및 붙임 조사결과(조사기간 2026.8.21.~10.5.).

개인정보보호위원회, 「외부 설문도구 이용 시 개인정보 처리 준수 사항에 대해 보다 명확히 안내하겠습니다」 보도참고자료, 2026.10.16. https://www.pipc.go.kr/np/cop/bbs/selectBoardArticle.do?bbsId=BS074&mCode=C020010000&nttId=12585

경북도민일보, 「천하람 "국민사서함 3 만 8000 건 답변도 없이 폐기"」, 2026.10.29. https://www.hidomin.com/news/articleView.html?idxno=727010

경향신문, 「[단독]10 만명 공직자 정보 유출…"파기 완료" 위탁업체 1 년 반 허위 보고, 권익위는 몰랐다」, 2026.10.21. https://www.khan.co.kr/article/202610211038011

경향신문, 「경찰 "북한 해커 조직, 국내 10 여 개 방산업체 기술 탈취"」, 2024.4.23. https://www.khan.co.kr/article/202404231200001

경향신문, 「고객정보 306 만건 유출 '모두투어' …과징금 7 억 5000 만원」, 2025.3.13. https://www.khan.co.kr/article/202503131225001

경향신문, 「네이버 인기 블로그 계정 해킹하고 판매한 일당 검거」, 2022.11.16. https://www.khan.co.kr/article/202211161628001

교육부, 「교육부 정보보안 기본지침」(2023.11.21.) 제 41 조제 7 항.

국가법령정보센터, 「클라우드컴퓨팅서비스 보안인증에 관한 고시」(과학기술정보통신부고시 제 2023-4 호, 2023.1.31.). https://www.law.go.kr/행정규칙/클라우드컴퓨팅서비스보안인증에관한고시

국가정보원, 「국가 사이버보안 기본지침」(2026.5.1.) 제 2 조, 제 24 조의 3·제 24 조의 4. https://www.ncsc.go.kr/template/resources/file/nis_guide_lines_2023_1_31.pdf

국가정보원, 「국가·공공기관 민간클라우드 컴퓨팅서비스 도입 가능목록」(2026.9.30. 기준).

김·장 법률사무소, 「 '클라우드컴퓨팅서비스 보안인증에 관한 고시' 개정안 시행」, 2023. https://www.kimchang.com/ko/insights/detail.kc?sch_section=4&idx=26738

뉴스 1, 「국정원, 공공 클라우드 보안체계 구체화…등급별 이용조건 공개」, 2026.9.22. https://www.news1.kr/it-science/security-hacking/6297831

뉴스 1, 「토종 1 위 ERP 더존비즈온 해킹… 고객사 민감정보 유출 가능성」, 2026.10.26. https://www.news1.kr/it-science/security-hacking/6331870

뉴시스, 「6 개 지역서 학교 구글 계정 11 만개 해킹…"비번 360 만개 변경 완료"」, 2026.10.22. https://nwww.newsis.com/view/NISX20261022_0003837339

뉴시스, 「대전 학교 구글 비번 7 만개 '무단 변경' …졸업생·퇴직자도 피해 가능성」, 2026.10.13. https://nwww.newsis.com/view/NISX20261013_0003824309

동아일보, 대통령 순방단 개인정보 유출 보도, 2026.11.3. https://www.donga.com/news/Politics/article/all/20261103/134957843/1

디지털투데이, 「국정원, 국가·공공기관 도입 가능 클라우드 서비스 89 개 공개」, 2023.8.11. https://www.digitaltoday.co.kr/news/articleView.html?idxno=484572

미디어오늘, 「직원 가족·입사 지원자 개인정보 '탈탈' 털린 콜센터 업체」, 2026.4.23. https://www.mediatoday.co.kr/news/articleView.html?idxno=333978

보안뉴스, 「 '사칭' 이라던 자비스, 실제 뚫렸다... 공동인증서·결제 정보 등 유출 확인」, 2026.11.6. https://www.boannews.com/news/articleView.html?idxno=147080

보안뉴스, 「[단독] 北김수키, 국세청·네이버 사칭 공격 활개..계정 도용 주의보!」, 2025.3.2. https://www.boannews.com/news/articleView.html?idxno=136326

보안뉴스, 「[대한민국 털렸다] '프랙' 보고서 사실이었다...행안부 온나라 시스템 등 해킹 확인」, 2025.10.17. https://www.boannews.com/news/articleView.html?idxno=139807

보안뉴스, 「[더존비즈온 사태] 11 월 5 일 유출 의심 기업 현황... 서울시 육아종합지원센터 유출 가능성」, 2026.11.5. https://www.boannews.com/news/articleView.html?idxno=147019

보안뉴스, 「[더존비즈온 사태] 급여 계좌부터 가족 주민번호까지... 더존비즈온 해킹이 '중대 사고'인 이유」, 2026.11.2. https://www.boannews.com/news/articleView.html?idxno=146948

보안뉴스, 「거제시 이어 경기도 산하 홈피까지 개인정보 노출 위험 드러나... 지자체 보안 부실은 외주 탓?」, 2024.6.21. https://www.boannews.com/news/articleView.html?idxno=130782

보안뉴스, 「맑은소프트 개인정보 유출 규모 237 만건... 고객사 22 곳 불똥」, 2026.10.13. https://www.boannews.com/news/articleView.html?idxno=146361

윤대균(아주대학교), 「CSAP 및 FedRAMP 최근 동향」, 디지털서비스 이슈리포트 2024-07, 조달청, 2024.7.31. https://www.digitalmarket.kr/web/board/BD_board.view.do?domainCd=2&bbsCd=1030&bbscttSeq=20240731093432396&monarea=00008

이스트시큐리티 ESRC, 「기능별 C2 서버를 운용하는 Kimsuky 그룹의 새로운 LNK 악성코드 등장」, 2026.9.9. https://www.estsecurity.com/public/security-info/column/view/1183075

이현섭(법무법인 세움), 「구글폼 응답이 다른 응답자에게 보였다면 과태료 대상일까요? — 결정문 8 건의 기준」, 2026.10.19. https://datalaw.kr/posts/google-forms-survey-exposure-fine/

전자신문, 「보안인증 없는 구글폼…개보위 사업에 쓰였다」, 2026.10.15. https://www.etnews.com/20261015000353

KBS, 「[단독] "여론조사업체 15 곳 중 14 곳 법 위반" 개인 정보 '구멍'…실태도 '깜깜'」, 2025.4.25. https://news.kbs.co.kr/news/pc/view/view.do?ncd=8238025

MBC, 「[단독] "'1 호기 명단', 보안 업체서 고유 식별값 대신 원본 파일 올려"」, 2026.11.5. https://imnews.imbc.com/news/2026/politics/article/6863333_36911.html

MBC, 「북한 배후 해킹그룹, 챗 GPT 로 군 신분증 위조··피싱 공격 시도」, 2025.9.15. https://imnews.imbc.com/news/2025/econo/article/6756090_36737.html

MTN 머니투데이방송, 「[단독] 더존비즈온, 7 월 고객센터도 뚫렸다...개인정보 8 개 항목 유출」, 2026.11.5. https://news.mtn.co.kr/article/2026110511112249187

SBS, 「[단독] 북, 총선 전 여론조사 기관 공격…선거 혼란 노렸나」, 2024.5.24. https://news.sbs.co.kr/news/endPage.do?news_id=N1007658916

2. 해외 문헌

Anthropic, "Detecting and countering misuse of AI: August 2025", 2025.8.27. https://www.anthropic.com/news/detecting-countering-misuse-aug-2025

Anthropic, "Disrupting the first reported AI-orchestrated cyber espionage campaign", 2025.11.13. https://www.anthropic.com/news/disrupting-AI-espionage

CloudSEK, "Compromising Google Accounts: Malwares Exploiting Undocumented OAuth2 Functionality for session hijacking", 2023.12.29. https://www.cloudsek.com/blog/compromising-google-accounts-malwares-exploiting-undocumented-oauth2-functionality-for-session-hijacking

Forbes(Davey Winder), "Google Forms Used In Password-Stealing Spree: What You Need To Know"(Zimperium 연구 인용), 2020.11.3. https://www.forbes.com/sites/daveywinder/2020/11/03/always-trust-google-here-are-256-password-stealing-reasons-you-shouldnt/

Google Cloud, "April 2023 Threat Horizons Report". https://services.google.com/fh/files/blogs/gcat_threathorizons_full_apr2023.pdf

Google Security Blog, "New research: How effective is basic account hygiene at preventing hijacking", 2019.5.17. https://security.googleblog.com/2019/05/new-research-how-effective-is-basic.html

Google Threat Intelligence Group, "GTIG AI Threat Tracker: Advances in Threat Actor Usage of AI Tools", 2025.11.5. https://cloud.google.com/blog/topics/threat-intelligence/threat-actor-usage-of-ai-tools

Google Threat Intelligence Group, "The Cost of a Call: From Voice Phishing to Data Extortion", 2025.6.4(2025.8 갱신). https://cloud.google.com/blog/topics/threat-intelligence/voice-phishing-data-extortion

Google, "Google Workspace's continuous approach to mitigating indirect prompt injections", 2026.4.2. https://blog.google/security/google-workspaces-continuous-approach-to-mitigating-indirect-prompt-injections/

Kaspersky, "Beware of Google Forms bearing crypto gifts", 2025.7.24. https://www.kaspersky.com/blog/google-forms-scam/53909/

Mandiant(Google Cloud), "UNC5537 Targets Snowflake Customer Instances for Data Theft and Extortion", 2024.6.10. https://cloud.google.com/blog/topics/threat-intelligence/unc5537-snowflake-data-theft-extortion

Microsoft Threat Intelligence, "From cookie theft to BEC: Attackers use AiTM phishing sites as entry point to further financial fraud", 2022.7.12. https://www.microsoft.com/en-us/security/blog/2022/07/12/from-cookie-theft-to-bec-attackers-use-aitm-phishing-sites-as-entry-point-to-further-financial-fraud/

Noma Security, "GeminiJack: the Google Gemini zero-click vulnerability leaked Gmail, Calendar and Docs data", 2025.12.8. https://noma.security/blog/geminijack-google-gemini-zero-click-vulnerability

Okta Threat Intelligence, "Okta observes v0 AI tool used to build phishing sites", 2025.7.1. https://www.okta.com/blog/threat-intelligence/okta-observes-v0-ai-tool-used-to-build-phishing-sites/

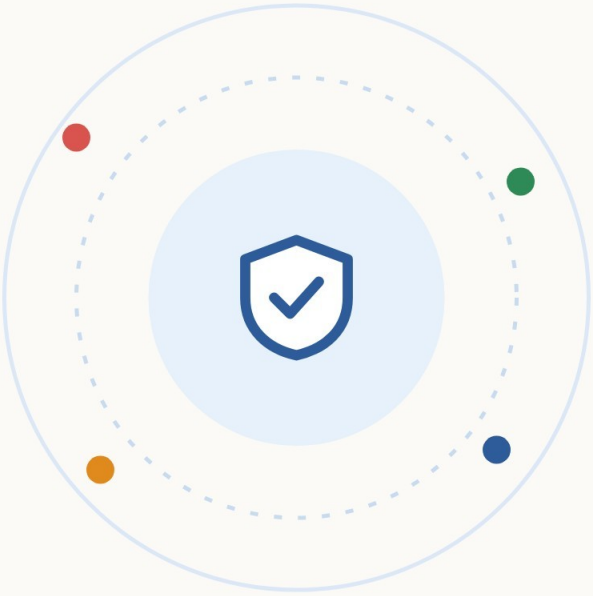
P. Reddy, A. S. Gujral, "EchoLeak: The First Real-World Zero-Click Prompt Injection Exploit in a Production LLM System", arXiv:2509.10540, 2025.9. https://arxiv.org/abs/2509.10540

부록. 용어 정의

용어	정의
폼(설문·신청 양식)	설문·신청·접수에 사용하는 온라인 양식. 구글폼·네이버폼 등 외부 서비스가 대표적임
클라우드 보안인증(CSAP)	공공기관에 클라우드 서비스를 제공하려는 사업자의 보안 수준을 국가가 평가하여 인증하는 제도
도입 가능 목록	국가정보원이 공개하는 「국가·공공기관 민간 클라우드 컴퓨팅서비스 도입 가능 목록」
SaaS	설치 없이 인터넷으로 이용하는 소프트웨어 서비스
정보탈취 악성코드	PC 에 저장된 비밀번호·로그인 세션·인증서 등을 탈취하여 외부로 전송하는 악성코드
세션 탈취	로그인 상태 정보를 탈취하여 비밀번호·2 단계 인증 없이 접속하는 공격
피싱 저항형 인증	보안키·패스키와 같이 인증수단을 정상 사이트 주소에 암호학적으로 결합하여 가짜 사이트에서 작동하지 않도록 한 인증
간접 프롬프트 인젝션	메일·문서·응답 등 AI 가 읽는 자료에 명령을 숨겨 AI 비서의 행동을 조종하는 공격
AI 에이전트	목표를 부여하면 여러 도구를 스스로 호출하며 작업을 연속 수행하는 AI
웹셸	웹 서버에 은밀히 설치되어 서버를 원격 조종하는 악성 파일

기술정책보고서

AI 시대, 설문·신청·수집 단계의 보안 위협과 대응



설문·신청서 한 장에도 국민의 정보가 담깁니다.
안전한 수집이 신뢰받는 행정과 서비스의 출발점입니다.

개인정보보호진흥원

(재)한국컨설팅산업재단 부설 · 서울특별시 송파구 양재대로71길 20-30, 2층

02-501-2906
전화

cs@kcf-korea.org
이메일

02-558-5146
팩스

www.kcf-korea.org/privacy-center
웹사이트

진흥원 바로가기

(재)한국컨설팅산업재단 T 02-555-9091 · F 02-455-0090 · www.kcf-korea.org

발간번호 2026-11-01 · 발간일 2026. 11. 10.

비매품 · 출처를 밝히고 인용할 수 있습니다